Оглавление

ВВЕДЕНИЕ 2
1. Базы знаний по атакам, использующим метод ICMP Echo Request 5
1.1. Базы знаний о сценариях реализации заданной атаки 5
1.2. База знаний об уязвимостях 24
1.2.1. Формирование множество уязвимостей 24
1.2.2. Риск-ландшафт 29
2. Частная политика противодействия заданной атаке 37
2.1. Частные регламенты выявления и регистрации инцидентов нарушения безопасности 37
2.2. Частные регламенты реагирования на инциденты нарушения безопасности 50
2.3. Частные регламенты ликвидации последствий инцидентов нарушения безопасности 62
3. Частные инструкции для противодействия рассматриваемой атаке 72
ЗАКЛЮЧЕНИЕ 83
СПИСОК ЛИТЕРАТУРЫ 85
Приложение А 89
Приложение Б 99

ВВЕДЕНИЕ

Актуальность исследования. Систематические кибератаки, подобные цунами, которые непрерывно обрушиваются на наше информационное пространство, требуют от нас обеспечения адекватной технической и организационно-правовой защиты современных автоматизированных информационных систем (АИС). Это необходимо для защиты от различных комбинаций векторов (сценариев) атак и уязвимостей АИС, которые используются злоумышленниками.

В связи с этим, специалистам, обеспечивающим защиту АИС, приходится столкнуться с сотнями известных вредоносных сценариев и тысячами обнаруженных уязвимостей. Эти уязвимости порождают десятки тысяч комбинаций, каждая из которых имеет свою специфику реагирования средств и органов защиты.

В этом контексте единственным эффективным средством противодействия является регламентация реагирования на киберинциденты, подкрепленная адекватным анализом рисков. Это включает в себя разработку и внедрение стандартов и процедур, которые определяют, как реагировать на различные типы киберинцидентов, а также проведение регулярного анализа рисков для определения потенциальных угроз и уязвимостей.

Именно в этом контексте актуально данное исследование, посвященное атакам типа “проверка эхо-запроса ICMP”, которые активно используются в современном киберпространстве. Эти атаки могут быть использованы злоумышленниками для определения активности и доступности систем, что делает их особенно опасными.

С учетом вышеизложенного и нормативной базы, можно сформулировать следующее: для эффективной защиты от кибератак необходимо не только техническое обеспечение, но и грамотная организационно-правовая политика, а также регулярное обучение персонала. Кроме того, необходимо постоянное мониторинг и анализ киберугроз, чтобы быть в курсе последних тенденций и методов атак. Только такой комплексный подход позволит эффективно противостоять современным киберугрозам.

– **объект исследования**, является информационное пространство, включающее корпоративные сети, телекоммуникационные системы (ТКС) и другие защищаемые сущности, которые подвергаются кибератакам типа "проверка эхо-запроса ICMP";

– **предмет исследования** в качестве оценки рисков возникновения киберинцидентов, формирования мер реагирования на них и ликвидации их последствий в условиях реализации компьютерных атак вида проверка эхо-запроса ICMP;

– **цель исследования**, является повышение защищенности автоматизированных информационных систем (АИС) за счет построения риск-ландшафта и регламентации противодействия атакам типа "проверка эхо-запроса ICMP".

Исследование аналогов, а также существующих баз данных и знаний по кибератакам и уязвимостям позволяет констатировать наличие следующих (существенных для настоящей тематики) **противоречий между:**

– Существующие методы и формы оценки рисков не всегда позволяют эффективно выявлять и анализировать атаки типа "проверка эхо-запроса ICMP"

– Необходимость представления риск-анализа атак в виде сечений по векторам атак сочетаниях кибератак вида "проверка эхо-запроса ICMP" и соответствующих им уязвимостей.

Для разрешения перечисленных противоречий и достижения поставленной цели необходимо решить следующие **задачи:**

– Создание базы знаний, описывающей сценарии (векторы) реализации заданной атаки из баз знаний CAPEC, NIST, MITRE ATT&CK, БДУ, CISA KEV. Эта база знаний будет использоваться в качестве руководства по обнаружению и предотвращению подобных атак в будущем.

– Построение риск-ландшафта для атак типа "проверка эхо-запроса ICMP", реализуемых в отношении АИС, с учетом сечений по векторам атак и уязвимостям. Это позволит выявить наиболее опасные сочетания атак и уязвимостей.

– Агрегирование знаний из различных баз данных и построение регламентов

реагирования на инциденты и ликвидации их последствий для атак типа "проверка эхо-запроса ICMP".

На защиту выносятся следующие **результаты** исследования:

- Риск-ландшафт представляет собой совокупность сечений по векторам атак и уязвимостям, что позволило выявить наиболее опасные их сочетания, в отношении которых необходимо первоочередное регулирование рисков.
- Базы знаний включают информацию о сценариях (векторах) реализации определенной атаки и об уязвимостях, используемых этой атакой. Эти базы знаний представляют собой собрание данных о типичных или известных методах атак и уязвимостях в информационных системах.
- Регламенты были получены в результате агрегирования знаний из баз CAPEC, NIST, MITRE ATT&CK, БДУ, CISA KEV по противодействию атакам типа "проверка эхо-запроса ICMP".

1. Базы знаний по атакам, использующим метод ICMP Echo Request

1.1. Базы знаний о сценариях реализации заданной атаки

Протокол управления сообщениями в Интернете (ICMP) является основным протоколом, используемым в сети Интернет для передачи сообщений об ошибках и операционной информации. ICMP является частью стека протоколов Интернета, определенного в стандарте RFC 792. Он работает на уровне сети модели OSI и используется рядом с протоколами IP (Internet Protocol).

ICMP предназначен для использования сетевыми устройствами, такими как маршрутизаторы, для отправки сообщений об ошибках и операционной информации другим сетевым устройствам. Например, если маршрутизатор не может маршрутизировать пакет IP из-за проблемы с доставкой, он может отправить сообщение ICMP об ошибке источнику.

ICMP включает в себя различные типы сообщений, включая:

Echo Request и Echo Reply (Ping): Эти сообщения используются для проверки доступности сетевого устройства. Echo Request (запрос эха) отправляется от источника к целевому устройству, которое затем отправляет Echo Reply (ответ эха) обратно к источнику.

Destination Unreachable: Это сообщение отправляется, когда пакет не может быть доставлен до его назначения.

Time Exceeded: Это сообщение отправляется, когда пакет не достигает своего назначения в течение определенного времени.

Parameter Problem: Это сообщение отправляется, когда сетевое устройство обнаруживает проблему с одним или несколькими полями в заголовке IP пакета.

Важно отметить, что, хотя ICMP может быть полезен для диагностики проблем с сетью, он также может быть использован злоумышленниками для проведения атак на сетевые системы. Например, атака “Ping of Death” использует специально сформированные ICMP Echo Request пакеты для вызова сбоев и перезагрузок в целевых системах.

Атака ICMP Echo Request Ping, известная как ‘Ping’, используется для определения, отвечает ли целевая система. Если запрос не блокируется брандмауэром или ACL, целевой хост ответит датаграммой ICMP Type 0 Echo Reply. Этот тип

обмена обычно называют ‘Ping’ из-за утилиты Ping, присутствующей почти во всех операционных системах.

Ping, как обычно реализован, позволяет пользователю проверить активность хостов, измерить время в обе стороны и измерить процент потери пакетов1. Выполнение этой операции для диапазона хостов в сети называется ‘Ping Sweep’. Хотя утилита Ping полезна для обнаружения хостов в малом масштабе, она не предназначена для быстрого или эффективного обнаружения хостов в больших сетевых блоках. Были созданы другие сканирующие утилиты, которые упрощают выполнение операций ICMP ping sweep.

Большинство сетей фильтруют входящие сообщения ICMP Type 8 по соображениям безопасности. В результате разработаны различные другие методы выполнения ping sweeps. Важно понимать, что ключевая цель безопасности злоумышленника - узнать, жив ли IP-адрес, или есть ли отзывчивый хост. Для этого практически любой тип сообщения ICMP, определенный в RFC 792, полезен. Злоумышленник может перебирать различные типы сообщений ICMP, чтобы определить, есть ли дыры в конфигурации брандмауэра.

Когда ICMP ping sweeps не удается обнаружить хосты, другие протоколы могут быть использованы для той же цели, такие как TCP SYN или ACK сегменты, UDP датаграммы, отправленные на закрытые порты, и т.д.

Для выполнения этого типа атаки злоумышленнику требуется умение отправить ICMP Type 8 запрос (Echo Request) на удаленную цель и получить ICMP Type 0 сообщение (ICMP Echo Reply) в ответ. Любые брандмауэры или списки контроля доступа между отправителем и получателем должны разрешать ICMP Type 8 и ICMP Type 0 сообщения, чтобы операция ping была успешной.

Злоумышленнику также потребуются сканеры или утилиты, которые предоставляют возможность отправлять пользовательские ICMP запросы.

В некоторых случаях, злоумышленники могут использовать ICMP flood attack, где они отправляют большое количество ICMP echo-request пакетов на целевое устройство, заставляя его отвечать на каждый запрос, что может привести к перегрузке сети.

В отчете Cloudflare за 2023 год отмечено, что ICMP Echo Request атаки

составляют значительную часть всех DDoS-атак на сетевом уровне. Например, в некоторых центрах обработки данных объем вредоносного трафика достигал до 17% от общего трафика, проходящего через эти центры (The Cloudflare Blog).

В 2024 году количество DDoS-атак, включая ICMP атаки, продолжает расти. Объем атакующего трафика увеличивается, и методы атак становятся все более сложными. Например, в некоторых регионах до 80% всего трафика было связано с сетевыми DDoS-атаками (The Cloudflare Blog) (Connect, Protect and Build Everywhere) .

Меры противодействия: Для борьбы с такими атаками обычно используются различные методы фильтрации и ограничения ICMP трафика на уровне маршрутизаторов и серверов. Компании, такие как Cloudflare, предоставляют специализированные решения для смягчения последствий DDoS-атак, перераспределяя нагрузку и блокируя подозрительный трафик на своих сетевых границах (Connect, Protect and Build Everywhere) (Cyphere).

Таким образом, ICMP Echo Request (Ping) атаки остаются одной из популярных форм DDoS-атак в 2024 году, составляя значительную часть всех сетевых атак и требуя комплексных мер защиты для предотвращения их последствий.

Как мы видим из диаграммы, представленной ниже, ICMP Echo Request атаки составляю почти 1/5 всех DDoS-атак в мире. Из нее мы можем понять, что каждая 5 такая происходит через ICMP Echo Request.



Рис.1. – Диаграмма DDoS-атак в мире.

Рассмотрим так же количество атак по годам и сделаем выводы:

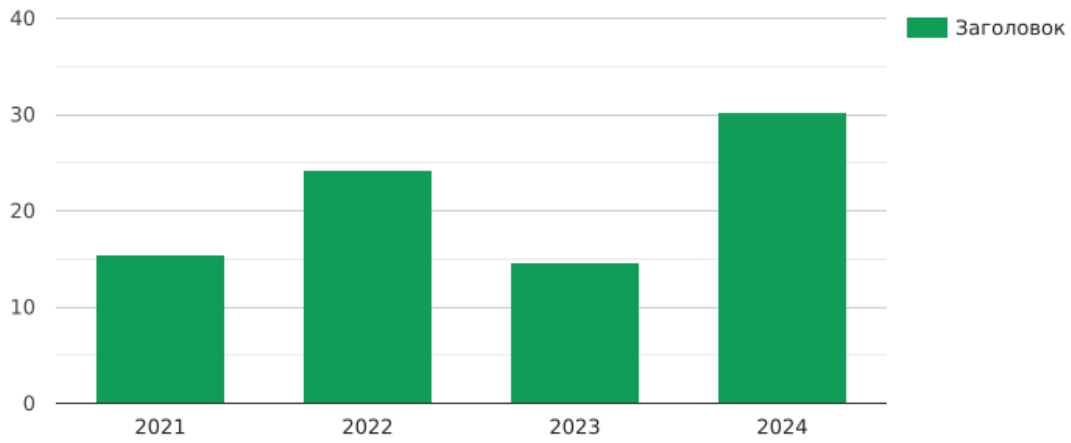


Рис.2. Диаграмма атак по годам.

Как мы можем видит по диаграмме мы можем видеть высокие показатели в 2022 и 2024 году, это связано с началом проведения специальной военной операцией в 2022 году и выборами президента в 2024 году.

С учетом предоставленных данных за 2022 становится очевидным, что большое количество атак ICMP Echo Request исходит из разных регионов мира. В частности, Европа (в особенности северная часть), восточная и западная части Северной Америки, а также Южная Америка и Азия участвуют в этих атаках. Не следует однозначно утверждать, что карта точно отображает первоисточники атак, поскольку некоторые атаки могут быть организованы через VPN-серверы. Кроме того, ботнеты могут использовать ротацию устройств, что затрудняет оценку полного масштаба. Сами атаки также сложно обнаружить и фильтровать (1).

Интересно отметить, что Национальный координационный центр по компьютерным инцидентам (НКЦКИ) опубликовал список из 17,5 тысяч IP-адресов, которые, предположительно, используются для проведения DDoS-атак на информационные ресурсы. С помощью этих данных и геоблокировки можно отсечь значительную часть нелегитимного трафика.

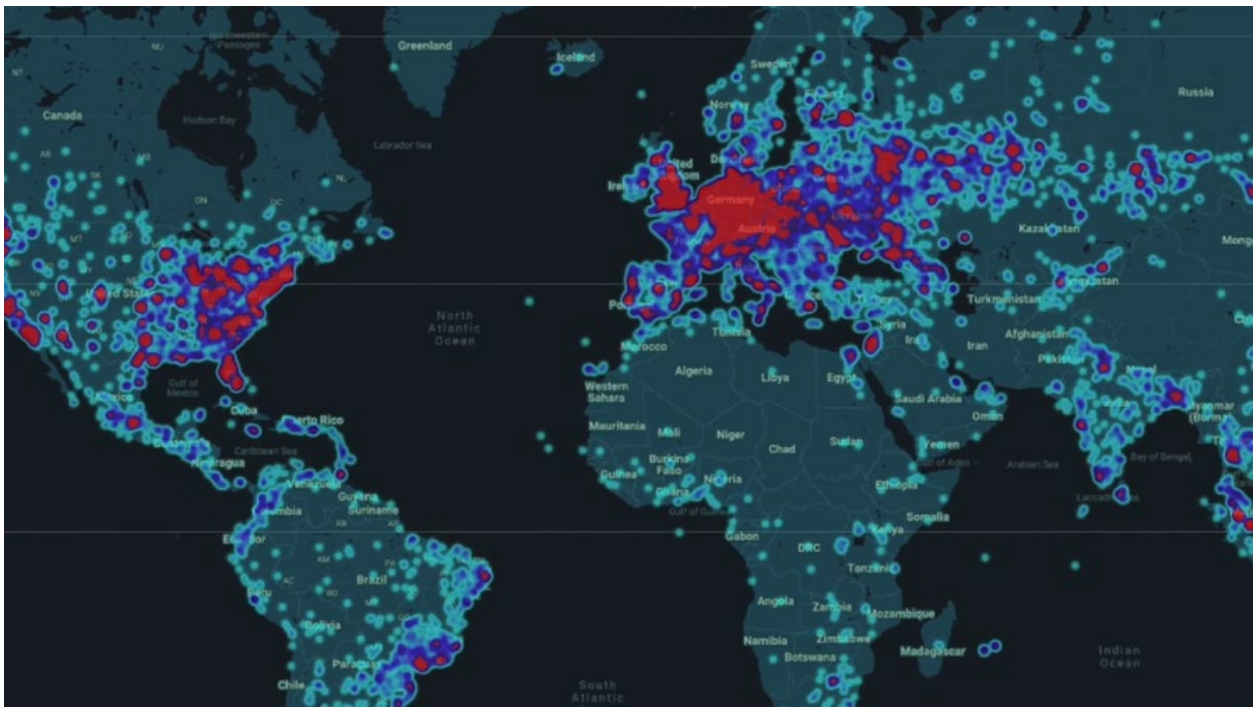


Рис.3. – Карта источников DDoS-атак

Далее рассмотрим 2024 год. Во втором квартале 2024 года ландшафт DDoS-атак в России значительно изменился. Если ранее аналитики компании фиксировали постоянный рост атак на ключевые индустрии, то в апреле и мае этого года число атак увеличилось лишь на несколько отраслей, тогда как на большинство индустрий количество атак снизилось (2).

Согласно данным аналитиков, с 1 по 30 апреля 2024 года число DDoS-атак уменьшилось на следующие сектора по сравнению с аналогичным периодом прошлого года:

- Финансовая сфера: -54%
- Онлайн-ритейл: -37%
- Сфера развлечений: -28%

В мае снижение было еще более заметным:

- Финансовые организации: -81%
- Электронная коммерция: -63%
- Сфера развлечений: -42%

Рост атак на другие отрасли

Эксперты также выявили рост числа DDoS-атак в других секторах. С 1 по 30 апреля 2024 года:

- Интернет-провайдеры: +126%

- Облачные провайдеры: +38%
- Государственные сервисы: +42%

Рост атак на эти отрасли продолжился и в мае. С 1 по 20 мая 2024 года:

- Интернет-провайдеры: +134%
- Облачные провайдеры: +53%
- Государственные организации: +61%

Эти данные подчеркивают критическую важность внедрения надежных мер защиты. Без надлежащих инструментов и стратегий безопасности организации подвергаются риску серьезных последствий, таких как финансовые потери и репутационный ущерб. Поэтому необходимо уделять особое внимание укреплению защиты от таких атак и регулярно обновлять системы безопасности для эффективного противодействия угрозам.

Прежде чем разрабатывать механизмы защиты, важно понять, как устроена атака. Для формирования её вектора проанализируем классификационные схемы сетевых атак, такие как MITRE ATT&CK, CAPEC и NIST 800-115.

При использовании метода ICMP Echo Request злоумышленники могут преследовать несколько целей:

- Проверка доступности узлов сети: Определение, какие устройства активны и доступны в сети, что помогает злоумышленнику составить карту сети.
- Обнаружение активных IP-адресов: Сканирование диапазона IP-адресов для выявления активных хостов. Это помогает определить потенциальные цели для дальнейших атак
- Сбор информации о сети: Получение данных о задержке, времени отклика и маршрутизации. Анализируя время отклика ICMP Echo Request пакетов, злоумышленник может оценить топологию сети и маршруты передачи данных.
- Изучение конфигурации сети: Понимание сетевых устройств, таких как маршрутизаторы и брандмауэры, и их поведения при обработке ICMP трафика. Это может помочь в выявлении слабых мест в конфигурации сети.
- Подготовка к более сложным атакам: Использование результатов сканирования для планирования последующих шагов, таких как более целенаправленные атаки на выявленные уязвимости или проникновение в сеть.

- DDoS-атаки: Перегрузка целевого узла большим количеством ICMP Echo Request пакетов. Это может привести к исчерпанию ресурсов цели (например, пропускной способности или вычислительных мощностей), что вызывает отказ в обслуживании.
- Скрытие других атак: Использование ICMP Echo Request для отвлечения внимания от других, более целенаправленных атак. Массовый ICMP трафик может служить прикрытием для более скрытых методов проникновения.
- Оценка защиты сети: Тестирование реакции системы безопасности на ICMP трафик. Злоумышленники могут использовать ICMP Echo Request для выявления и анализа работы средств защиты, таких как системы обнаружения вторжений (IDS) и брандмауэры.
- Обход ограничений доступа: Определение путей обхода ограничений, наложенных администратором сети. Например, если ICMP трафик разрешен через брандмауэр, злоумышленник может использовать его для связи с внутренними ресурсами сети.
- Мониторинг доступности целей: Постоянное отслеживание доступности ключевых ресурсов. Злоумышленники могут периодически посылать ICMP Echo Request пакеты, чтобы проверить, остаются ли цели активными и доступными.

Эти действия позволяют злоумышленникам собрать необходимую информацию для более сложных и целенаправленных атак, а также оценить защиту сети и найти возможные пути обхода существующих механизмов безопасности.

Для того чтобы атака была успешной, злоумышленник должен внимательно спланировать свои действия. Первым шагом является установление связи с целью и её тщательное изучение с использованием разнообразных методов и инструментов. Это поможет определить наиболее эффективный метод атаки, например, с использованием ICMP Echo Request.

В период подготовки злоумышленник собирает все необходимые ресурсы, от программного обеспечения до физических вычислительных мощностей, которые позволят провести запланированную атаку.

После завершения подготовки и сбора всех ресурсов, злоумышленник начинает атаку. Продолжительность атаки будет зависеть от поставленных целей, таких как

нанесение максимального ущерба или выполнение дополнительных задач, например, обеспечение длительного времени простоя цели.

Ниже приведена таблица с этапами проведения атаки методом ICMP Echo Request в соответствии с методологиями NIST 800-115.

Таблица 1 – Описание этапов проведения атаки

Этап	Техника атаки	Описание атаки
Планирование	Идентификация цели	Определение цели и оценка потенциальных уязвимостей для выбора методов атаки
	Анализ уязвимостей	Исследование системы для выявления уязвимостей, которые можно использовать для атаки
	Подбор инструментов	Определение необходимых инструментов и программ для проведения ICMP Echo Request атаки
Подготовка	Настройка окружения	Подготовка всех условий для проведения атаки, включая конфигурацию атакующей машины и параметры ICMP Echo Request
	Обработка данных	Подготовка необходимых данных, таких как изменение адресов отправителя и получателя
	Сбор ресурсов	Сбор всех необходимых ресурсов, включая программное обеспечение и вычислительные мощности
Атака	Начало атаки	Отправка ICMP Echo Request пакетов на целевую систему для перегрузки её ресурсов или нарушения нормальной работы
	Продолжение атаки	Повторная отправка запросов для усиления атаки и увеличения времени простоя системы
	Скрытие активности	Применение методов для сокрытия атаки, таких как изменение идентификаторов пакетов и случайное

		распределение времени между запросами

Использование ICMP Echo Request в атаках представляет собой значительную угрозу для информационной безопасности организаций. В данном разделе будет проведен анализ тактик и техник, связанных с использованием ICMP Echo Request, в контексте базы знаний MITRE ATT&CK.

MITRE ATT&CK представляет собой обширную базу данных, которая описывает различные тактики и техники, используемые злоумышленниками при атаках на информационные системы. Анализ тактик и техник, связанных с использованием ICMP Echo Request, в рамках MITRE ATT&CK, позволяет более глубоко понять характер атак и принять соответствующие меры защиты.

Методология NIST 800-115 предоставляет подход к анализу уязвимостей информационных систем и проведению атак с целью оценки их безопасности. Плавный переход от описания этапов проведения атаки в соответствии с NIST 800-115 к анализу тактик и техник в рамках MITRE ATT&CK позволяет глубже исследовать характер атак и определить соответствующие контрмеры.

Анализ тактик и техник, связанных с использованием ICMP Echo Request

Разведка (Reconnaissance):

- Злоумышленники могут использовать ICMP Echo Request для сканирования сети и определения активных узлов, что является отправной точкой для дальнейших атак.
- Методы, связанные с этой тактикой, включают Network Service Scanning (T1046) и Network Sniffing (T1040) в рамках MITRE ATT&CK.

Воздействие (Impact):

- ICMP Echo Request может быть использован для проведения DoS или DDoS-атак, что приводит к отказу в обслуживании и нарушению работы системы.
- Тактики, связанные с этой категорией, включают Denial of Service (T1499) в базе знаний MITRE ATT&CK.

Меры защиты

– Фильтрация и контроль ICMP-трафика для обнаружения аномалий и предотвращения атак.

– Регулярное обновление систем и применение патчей для устранения известных уязвимостей, связанных с протоколом ICMP.
– Обучение сотрудников о методах и тактиках, используемых злоумышленниками при атаках с использованием ICMP Echo Request.

Анализ тактик и техник, связанных с использованием ICMP Echo Request в рамках базы знаний MITRE ATT&CK, позволяет более глубоко понять характер атак и принять соответствующие меры защиты для обеспечения безопасности информационных систем. Связь с методологией NIST 800-115 обеспечивает системный и структурированный подход к анализу уязвимостей и реагированию на атаки.

Приведем ниже таблицу 2, где описаны тактики и техники реализации атаки на основе методологии MITRE ATT&CK.

Таблица 2 – Техники MITRE ATT&CK.

Тактика	Техника	Описание
Сбор и анализ информации	Сканирование сетевых служб (T1046)	Злоумышленники используют ICMP Echo Request для сканирования сети с целью определения активных сервисов и открытых портов на удаленных хостах. Это помогает им составить карту сети и выбрать цели для дальнейших атак.
	Анализ сети (T1040)	ICMP Echo Request может быть использован для пассивного прослушивания сетевого трафика. Атакующие могут анализировать полученные ответы на ICMP запросы для выявления активных узлов, сетевых служб и потенциальных уязвимостей.
	Туннелированние по протоколу (T1572)	Протокол ICMP может быть использован для туннелирования других протоколов, обеспечивая скрытую коммуникацию между атакующим и целевой сетью. Это может затруднить

		обнаружение атаки.
	Удаленное обнаружение системы (T1018)	ICMP Echo Request может использоваться для обнаружения удаленных систем в сети. Злоумышленники могут сканировать диапазон IP-адресов, отправляя ICMP запросы, и анализировать полученные ответы для определения активных узлов.
	Пассивное сетевое сканирование (T1040)	Злоумышленники могут использовать ICMP Echo Request для сканирования сети без активного воздействия на целевые устройства. Они отправляют ICMP запросы и анализируют полученные ответы для определения активных узлов в сети.
Обход защиты	Запутывание данных (T1001.001)	Обфускация данных в ICMP Echo Request может затруднить обнаружение атаки с использованием методов анализа сетевого трафика. Злоумышленники могут изменять содержимое ICMP запросов или ответов, чтобы скрыть свои действия.
	Запутанные файлы или информация (T1027)	ICMP Echo Request может использоваться для передачи обфусцированных данных, что затрудняет их обнаружение и анализ. Атакующие могут встраивать данные в ICMP

		запросы или ответы, используя различные методы обфускации.
	Система управления уклонением (T1024)	Атакующие могут использовать ICMP Echo Request для обхода систем обнаружения и контроля команд и управления. Они могут использовать протокол ICMP для установки и поддержания связи с удаленными управляющими серверами, обходя обычные методы обнаружения.
Воздействие	Отказ в обслуживании (T1499)	ICMP Echo Request может быть использован для проведения атак на отказ в обслуживании (DoS) или распределенных атак на отказ в обслуживании (DDoS). Атакующие могут перегрузить целевую систему ICMP запросами, что приведет к её недоступности для легитимных пользователей.
Распространение	Действующие учетные записи (T1078)	Злоумышленники могут использовать ICMP Echo Request для распространения атаки через компрометированные действующие учетные записи. Они могут отправлять ICMP запросы от имени компрометированных пользователей или учетных записей, что облегчает перемещение по сети и распространение вредоносных действий.
	Удаленные сервисы (T1021)	ICMP Echo Request может быть использован для распространения атаки через удаленные сервисы и службы в сети. Злоумышленники могут отправлять ICMP запросы, которые могут инициировать вредоносные действия на удаленных системах через уязвимые сервисы.

Атаки с использованием ICMP Echo Request могут варьироваться от относительно безвредных разведывательных операций до разрушительных атак на отказ в обслуживании. Например, CAPEC-194 описывает ICMP Flood, где злоумышленник отправляет большое количество ICMP Echo Request, чтобы перегрузить целевую систему и вызвать отказ в обслуживании. Этот метод может быть использован для временного выведения из строя серверов и сетевых устройств.

Интеграция данных о таких атаках в CAPEC позволяет более эффективно выявлять и предотвращать угрозы, связанные с ICMP Echo Request. Это включает мониторинг сетевого трафика на предмет аномальной активности, настройку систем обнаружения вторжений для фильтрации ICMP трафика, и разработку стратегий реагирования на инциденты. Таким образом, использование CAPEC в анализе атак с ICMP Echo Request помогает создавать более защищенные информационные системы и лучше понимать, как злоумышленники могут эксплуатировать этот протокол.

CAPEC описывает атаки на различных уровнях абстракции, от высокоуровневых стратегий до конкретных техник и методов. Это помогает специалистам по кибербезопасности видеть общие черты между различными атаками и использовать этот опыт для защиты своих систем. Каждая запись в CAPEC включает описание атаки, возможные векторы атаки, примеры и методы защиты. Такой систематизированный подход позволяет более точно оценивать риски и принимать обоснованные решения по защите информационных систем.

Одним из ключевых аспектов CAPEC является её интеграция с другими стандартами и фреймворками, такими как MITRE ATT&CK и NIST. Это обеспечивает единообразие и согласованность в подходах к кибербезопасности. Организации могут использовать CAPEC для формирования политики безопасности, планирования тестов на проникновение и обучения персонала. Кроме того, CAPEC помогает разработчикам программного обеспечения идентифицировать потенциальные уязвимости на ранних стадиях разработки и разрабатывать более безопасные продукты.

Описание общих механизмов и шаблонов атак CAPEC, которые используют для атак типа «Проверка эхо-запроса ICMP».

Таблица 3 – Описание механизмов м шаблонов атак CAPEC

Механизм атаки	Шаблон атаки	Описание атаки
Сбор и анализ информации	Сетевая разведка с помощью ICMP (CAPEC-290)	Злоумышленник использует ICMP Echo Request для сканирования сети и выявления активных узлов и сетевых служб. Отправка ICMP запросов к широкому диапазону IP-адресов позволяет определить активные узлы и их характеристики.
	Сканирование сетевых служб (CAPEC-292)	ICMP Echo Request используется для сканирования сети и выявления активных сервисов и открытых портов на удаленных хостах. Это позволяет злоумышленникам составить карту сети и выбрать цели для дальнейших атак.
Злоупотребление существующей функциональностью	ICMP-туннелирование (CAPEC-235)	Использование ICMP Echo Request для туннелирования данных через сеть, обхода сетевых фильтров и межсетевых экранов. Злоумышленники инкапсулируют команды или данные внутри ICMP Echo Request, обеспечивая скрытую передачу данных.
	Отказ в обслуживании через ICMP Flood (CAPEC-489)	Злоумышленник отправляет большое количество ICMP Echo Request к целевой системе, что приводит к перегрузке её ресурсов и отказу в обслуживании. Атака используется для временного выведения из строя серверов, маршрутизаторов и других сетевых устройств.
Вступление в обманчивые	Ping of Death (CAPEC-661)	Атака включает отправку слишком большого ICMP Echo Request, что может привести к

действия		сбою или зависанию целевой системы. Этот метод эксплуатации уязвимостей обработки сетевых пакетов может вызвать отказ в обслуживании.
	Перенаправление ICMP (CAPEC-100)	Использование ICMP Echo Request для обмана сетевых устройств, заставляя их изменять маршруты трафика, что позволяет злоумышленникам перенаправлять трафик через контролируемые узлы или создавать петли маршрутизации.
Обход защитных механизмов	Фрагментация ICMP	Разделение ICMP Echo Request на фрагменты для обхода средств обнаружения вторжений (IDS) и межсетевых экранов, что затрудняет их обнаружение и блокировку.
Эвакуация данных	Фильтрация данных с помощью ICMP (CAPEC-567)	Использование ICMP Echo Request для передачи данных из скомпрометированной системы, что позволяет скрытно эвакуировать конфиденциальную информацию.
Командирование и управление	Управление с помощью протокола ICMP	Использование ICMP Echo Request для передачи команд между злоумышленником и скомпрометированной системой, обеспечивая скрытный канал управления.

Для описания сценариев атак с использованием ICMP Echo Request, мы объединим данные из базы данных CAPEC, методологии MITRE ATT&CK и руководства NIST 800-115. Рассмотрим несколько типовых атак, их этапы и используемые тактики и техники.

Сценарий 1: Сбор информации о сети (Network Reconnaissance)

Цель: Определение активных узлов и их конфигураций в целевой сети.

1. Этапы атаки:

Планирование (NIST 800-115):

- Определить диапазон IP-адресов для сканирования.
- Подготовить инструменты для отправки ICMP Echo Request (например, nmap, ping).

2. Сканирование (NIST 800-115):

- Отправить ICMP Echo Request на все IP-адреса в выбранном диапазоне.
- Злоумышленник анализирует ответы ICMP Echo Reply для выявления активных узлов.

3. Сбор данных (NIST 800-115):

- Собрать информацию о IP-адресах, времени отклика и других характеристиках ответов.

4. Анализ данных (NIST 800-115):

- Определение типа устройств и их конфигураций, на основе полученных данных.

Механизм атаки (CAPEC-303): Network Reconnaissance via ICMP

Описание: Злоумышленник использует ICMP Echo Request для выявления активных узлов в сети и сбора информации о них.

Тактика (MITRE ATT&CK): Reconnaissance

Техника (MITRE ATT&CK): Active Scanning (T1595)

Описание: Активное сканирование сети с целью сбора информации об активных узлах и их конфигурациях.

Сценарий 2: DDoS атака (Denial of Service via ICMP Flood)

Цель: Приведение к отказу в обслуживании целевой системы или сети.

Этапы атаки:

1. Планирование (NIST 800-115):

- Создание или аренда ботнета — сети зараженных устройств.
- Подготовка скриптов для отправки ICMP Echo Request с каждого устройства ботнета.

2. Запуск атаки (NIST 800-115):

- Одновременное отправление большого количества ICMP Echo Request на

целевой сервер или сеть с устройств ботнета.

3. Наблюдение и корректировка (NIST 800-115):

- Мониторинг состояния целевой системы и корректировка интенсивности атаки при необходимости.

Механизм атаки (CAPEC-489): Denial of Service via ICMP Flood

Описание: Злоумышленник отправляет большое количество ICMP Echo Request для перегрузки целевой системы, приводя к отказу в обслуживании

Тактика (MITRE ATT&CK): Impact

Техника (MITRE ATT&CK): Network Denial of Service (T1498)

Описание: Атака на сетевые ресурсы для создания отказа в обслуживании.

Сценарий 3: Обход межсетевых экранов с использованием ICMP туннелирования (ICMP Tunneling)

Цель: Обход сетевых фильтров и межсетевых экранов для скрытой передачи данных.

Этапы атаки:

1. Планирование (NIST 800-115):

- Установка инструмента для туннелирования (например, IcmpTunnel) на зараженном устройстве в сети жертвы и на контролирующем устройстве злоумышленника.

2. Создание ICMP туннеля (NIST 800-115):

- Инкапсуляция команд и данных в ICMP Echo Request пакеты.

3. Передача данных (NIST 800-115):

- Отправка ICMP Echo Request с инкапсулированными данными через межсетевой экран.
- Контролирующее устройство извлекает инкапсулированные данные.

4. Командование и управление (NIST 800-115):

- Отправка команд на зараженное устройство через ICMP туннель.

Механизм атаки (CAPEC-235): ICMP Tunneling

Описание: Использование ICMP Echo Request для создания туннеля и скрытой передачи данных через сетевые фильтры и межсетевые экраны.

Тактика (MITRE ATT&CK): Command and Control

Техника (MITRE ATT&CK): Application Layer Protocol (T1071)

Описание: Использование легитимных сетевых протоколов, таких как ICMP, для командования и управления.

Сценарий 4: Атака "Ping of Death"

Цель: Вызвать отказ в обслуживании или сбой системы.

Этапы атаки:

1. Планирование (NIST 800-115):

- Создание ICMP Echo Request с размером пакета, превышающим стандартный лимит (например, более 65535 байт).
- Подготовка инструментов для отправки таких пакетов.

2. Отправка пакета (NIST 800-115):

- Отправка "смертельного" ICMP пакета на целевую систему.

3. Обработка пакета (NIST 800-115):

- Целевая система пытается обработать слишком большой ICMP пакет, что вызывает переполнение буфера или другие ошибки.

4. Отказ в обслуживании (NIST 800-115):

- Система зависает, сбрасывается или становится недоступной.

Механизм атаки (CAPEC-660): Ping of Death

Описание: Отправка слишком большого ICMP Echo Request пакета, вызывающего сбой или отказ в обслуживании целевой системы.

Тактика (MITRE ATT&CK): Impact

Техника (MITRE ATT&CK): Endpoint Denial of Service (T1499)

Описание: Атака на конечные точки для создания отказа в обслуживании.

Сценарий 5: Обман маршрутизации с использованием ICMP Redirect

Цель: Изменение маршрутов трафика в сети жертвы для перехвата или создания петли маршрутизации.

Этапы атаки:

1. Планирование (NIST 800-115):

- Подготовка фальшивых ICMP Redirect сообщений.
- Определение ключевых узлов в сети, через которые проходит критический трафик.

2. Отправка ICMP Redirect (NIST 800-115):

- Отправка фальшивых ICMP Redirect сообщений на выбранные устройства.
- Сообщение устройствам использовать неправильный маршрут для определенного IP-адреса или сети.

3. Изменение маршрута (NIST 800-115):

- Устройства принимают ICMP Redirect и изменяют маршруты трафика.

4. Перехват трафика (NIST 800-115):

- Трафик направляется через контролируемый злоумышленником узел, позволяя ему перехватывать и анализировать данные.
- В некоторых случаях создаются петли маршрутизации, что приводит к нарушению работы сети.

Механизм атаки (CAPEC-100): ICMP Redirect

Описание: Использование ICMP Echo Request для отправки ложных ICMP Redirect сообщений, изменяющих маршруты трафика в сети жертвы.

Тактика (MITRE ATT&CK): Defense Evasion

Техника (MITRE ATT&CK): Network Service Scanning (T1046)

Описание: Использование ложных ICMP Redirect сообщений для изменения маршрутов трафика и обхода защитных механизмов.

Эти сценарии атак демонстрируют, как злоумышленники могут использовать ICMP Echo Request для различных целей, от сбора информации до отказа в обслуживании и обхода защитных механизмов. Объединение данных из CAPEC, MITRE ATT&CK и NIST 800-115 позволяет получить полное представление о методах и тактиках, используемых при подобных атаках.

Таким образом, вектор атаки с использованием UDP-ping может быть представлен следующим образом:

$$A = \{VA_1, VA_2, VA_3, VA_4, VA_5\} \quad (1)$$

где VA_1 – Разведка сети;

VA_2 – Определение уязвимых систем;

VA_3 – Эксфильтрация данных;

VA_4 – Амплификация трафика;

VA_5 – Отказ в обслуживании.

1.2. База знаний об уязвимостях

1.2.1. Формирование множество уязвимостей

В условиях современного развития информационных технологий и сетевых коммуникаций, безопасность сетевых протоколов и служб является ключевым аспектом обеспечения надежности и устойчивости информационных систем. Одним из таких протоколов, широко применяемых для диагностики сетевых соединений и проверки доступности устройств в сети, является протокол ICMP (Internet Control Message Protocol). Специфическим сообщением данного протокола является ICMP Echo Request, более известный как ping-запрос. Этот инструмент используется для измерения времени отклика сетевого устройства и проверки его доступности, что делает его полезным как для системных администраторов, так и для обычных пользователей.

Однако, несмотря на свою полезность, ICMP Echo Request также может представлять собой значительную угрозу безопасности, если его использование не контролируется должным образом. Уязвимости, связанные с этим протоколом, могут быть использованы злоумышленниками для проведения различных типов атак на сетевые инфраструктуры и устройства. База данных уязвимостей ФСТЭК (Федеральная служба по техническому и экспортному контролю) содержит множество примеров таких уязвимостей и описывает методы их использования в целях нарушения безопасности.

База данных уязвимостей ФСТЭК (БДУ ФСТЭК) является одним из ключевых источников информации о различных угрозах и уязвимостях, связанных с информационными системами. В БДУ ФСТЭК содержатся описания уязвимостей, методы их эксплуатации, а также рекомендации по защите. Например, в базе можно найти данные о том, как злоумышленники могут использовать ICMP Echo Request для проведения атак типа "отказ в обслуживании" (Denial of Service, DoS). В этом случае злоумышленник может отправлять большое количество ICMP Echo Request пакетов на целевое устройство или сеть, что приводит к перегрузке и, в конечном итоге, к недоступности сервисов. Такая атака может быть усугублена с использованием техники под названием "smurf attack". В рамках этой атаки злоумышленник отправляет ICMP Echo Request на широковещательный адрес сети с поддельным IP-

адресом жертвы. Ответы на эти запросы возвращаются к жертве, что вызывает значительную перегрузку системы.

Другим важным источником информации о уязвимостях является Национальная база данных уязвимостей (National Vulnerability Database, NVD), управляемая Национальным институтом стандартов и технологий (NIST) США. В этой базе также содержатся подробные описания уязвимостей, включая те, которые связаны с ICMP Echo Request. Эти уязвимости могут быть использованы для проведения разведывательных операций (reconnaissance), когда злоумышленники применяют ping-запросы для выявления активных хостов в сети, их IP-адресов и других характеристик. Это позволяет более точно планировать дальнейшие атаки.

Также важным ресурсом является база данных Common Vulnerabilities and Exposures (CVE), которая предоставляет стандартные идентификаторы для уязвимостей. CVE записи часто содержат ссылки на подробные описания и анализы уязвимостей, что делает их ценным инструментом для специалистов по безопасности. Например, в CVE можно найти записи об ошибках и недоработках в реализации ICMP-протокола на конкретных устройствах, которые позволяют злоумышленникам выполнять произвольный код, получать несанкционированный доступ или вызывать сбои в работе системы.

Четвертая угроза связана с использованием ICMP для обхода сетевых фильтров и межсетевых экранов. В некоторых случаях злоумышленники могут использовать ICMP-пакеты для скрытой передачи данных, обфусцирования команд и управления вредоносным ПО, что делает их трудными для обнаружения традиционными методами мониторинга сетевого трафика. Это особенно опасно в корпоративных сетях, где важно не только контролировать доступ, но и обеспечивать целостность и конфиденциальность передаваемых данных.

И, наконец, ICMP Echo Request может служить средством для выявления и эксплуатации слабостей в конфигурациях сетевой инфраструктуры. Неправильные настройки межсетевых экранов, недостаточные политики фильтрации и мониторинга могут сделать сеть уязвимой для атак, использующих ICMP. Рекомендации по защите включают ограничение использования ICMP, внедрение строгих правил фильтрации на межсетевых экранах, регулярное обновление прошивок и программного

обеспечения сетевых устройств, а также использование инструментов для мониторинга и анализа сетевого трафика для выявления аномалий и потенциальных угроз.

Таким образом, несмотря на свою полезность для диагностики сетевых проблем, ICMP Echo Request может представлять значительные угрозы для безопасности сетевых инфраструктур. Понимание этих уязвимостей и принятие соответствующих мер защиты являются ключевыми аспектами обеспечения надежной и безопасной работы сетей и устройств.

Более детально уязвимости, связанные с атаками методом ICMP Echo Request, описаны в ресурсах CAPEC. На основе данных из CAPEC, а также из БДУ ФСТЭК и NVD была составлена таблица 4, в которой приводится описание множества уязвимостей, связанных с рассматриваемой атакой.

Таблица 4 - Таблица уязвимостей, связанных с использованием ICMP Echo Request.

Идентификатор уязвимости	Наименование уязвимости
CWE-200	Разглашение конфиденциальной информации неавторизованному пользователю
CWE-20	Неправильная проверка входных данных
CWE-119	Неправильное ограничение операций в пределах буфера памяти
CWE-400	Неконтролируемое потребление ресурсов
CWE-404	Неправильное завершение или освобождение ресурсов
CWE-287	Недостаточная проверка подлинности
CWE-306	Отсутствие проверки подлинности для критической функции
CWE-601	Перенаправление URL на недоверенный сайт
CWE-642	Внешний контроль критических данных состояния
CWE-918	Запросы со стороны сервера (SSRF)

CWE-200: Разглашение конфиденциальной информации неавторизованному пользователю. Эта уязвимость возникает, когда система непреднамеренно раскрывает конфиденциальную информацию, такую как IP-адреса, пароли или личные данные. Пример: использование ICMP Echo Request может позволить злоумышленнику определить активные хосты и их конфигурацию в сети, что может быть использовано для дальнейших атак.

CWE-20: Неправильная проверка входных данных. Эта уязвимость возникает, когда система не выполняет или неправильно выполняет проверку входных данных, что позволяет злоумышленнику вводить неожиданные или опасные данные, вызывая нежелательное поведение системы. Пример: неправильная обработка ICMP-запросов может привести к отказу в обслуживании или утечке информации.

CWE-119: Неправильное ограничение операций в пределах буфера памяти. Уязвимость, связанная с выходом за границы буфера, когда система записывает или считывает данные за пределами предназначенной области памяти. Пример: злоумышленник может отправить специально сформированные ICMP Echo Request, чтобы вызвать переполнение буфера и выполнить произвольный код.

CWE-400: Неконтролируемое потребление ресурсов. Эта уязвимость возникает, когда система не ограничивает потребление ресурсов, таких как процессорное время, память или сетевые соединения. Пример: злоумышленник может отправлять большое количество ICMP Echo Request, вызывая отказ в обслуживании путем истощения ресурсов.

CWE-404: Неправильное завершение или освобождение ресурсов. Уязвимость, связанная с неправильным завершением или освобождением ресурсов, таких как файлы, сетевые соединения или память, что может привести к утечкам памяти или отказу системы. Пример: неправильное освобождение ресурсов после обработки ICMP-запросов может привести к отказу в обслуживании.

CWE-287: Недостаточная проверка подлинности. Эта уязвимость возникает, когда система не выполняет должным образом проверку подлинности, позволяя неавторизованным пользователям получать доступ к защищенным функциям или данным. Пример: злоумышленник может использовать ICMP Echo Request для обхода механизмов проверки подлинности и получения доступа к системе.

CWE-306: Отсутствие проверки подлинности для критической функции. Уязвимость возникает, когда критическая функция системы не требует проверки подлинности, что позволяет неавторизованным пользователям выполнять действия, которые должны быть защищены. Пример: некоторые системы могут отвечать на ICMP-запросы без проверки подлинности, что позволяет злоумышленникам проводить разведку.

CWE-601: Перенаправление URL на недоверенный сайт. Уязвимость возникает, когда система перенаправляет пользователя на URL, который может быть контролируем злоумышленником. Пример: использование ICMP Echo Request для обнаружения перенаправлений на недоверенные сайты.

CWE-642: Внешний контроль критических данных состояния. Уязвимость возникает, когда внешний злоумышленник может управлять критическими данными состояния системы. Пример: использование ICMP Echo Request для изменения состояния сетевого устройства или его конфигурации.

CWE-918: Запросы со стороны сервера (SSRF). Эта уязвимость возникает, когда злоумышленник может заставить сервер делать небезопасные запросы на другие ресурсы. Пример: использование ICMP Echo Request для запуска SSRF-атак, что может привести к утечке данных или выполнению вредоносного кода.

Эти уязвимости могут быть использованы злоумышленниками для проведения различных атак, таких как отказ в обслуживании (DoS), обход межсетевых экранов и фильтров, а также для выполнения разведывательных операций в сети. Уязвимости, перечисленные выше, подтверждены различными базами данных и исследовательскими ресурсами, такими как CAPEC, БДУ ФСТЭК и NVD, что подчеркивает их значимость и распространенность в современном мире информационной безопасности.

Ниже представлена таблица 5 уязвимостей из базы данных CWE соотнесенные с конкретными образцами атак в базе данных CAPEC

Таблица 5 – Соотношения атак и используемых ими уязвимостей

Обозначение уязвимости в базе данных CWE	Обозначение образцов атак в базе данных CAPEC				
	285	295	296	294	487
CWE-200	X	X	X	X	X
CWE-20	X				
CWE-119	X				
CWE-400	X				X
CWE-404	X				
CWE-287	X				
CWE-306	X				
CWE-601	X				
CWE-642	X				
CWE-918	X				

1.2.2. Риск-ландшафт

Для начала приведем статистику по уязвимостям, указанным выше, их регистрацию и упоминание за 2023 год.

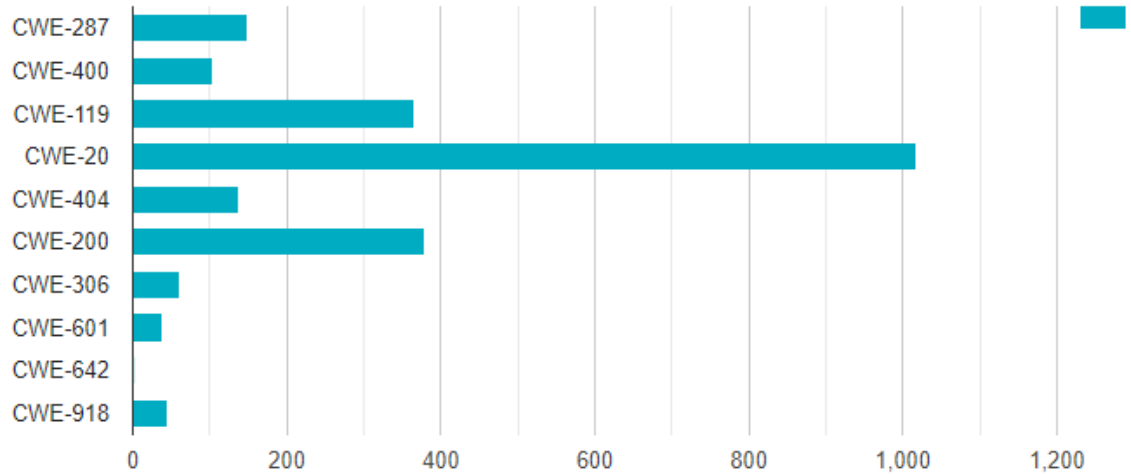


Рис. 4 – Количество регистраций и упоминаний уязвимостей за 2023 год

Результаты анализа инцидентов, зарегистрированных в БДУ ФСТЭК за 2023 год, показывают, что уязвимости, связанные с Неправильное ограничение операций

в пределах буфера памяти (CWE-119), Неправильная проверка входных данных (CWE-20) и разглашение конфиденциальной информации неавторизованному пользователю (CWE-200), являются наиболее распространенными и серьёзными угрозами для информационных систем.

Риск рассчитаем по формуле:

$$\overline{Risk_{sij}} = F_{sij} \times \overline{U_{sij}} \quad (2)$$

где F_{sij} – частота успешного использования *j*-ой уязвимости при реализации атаки типа *S* посредством *i*-го вектора;

$\overline{U_{sij}}$ – ущерб от реализации атаки типа *S* посредством *i*-го вектора.

Ущерб от реализации атаки рассчитаем в нормированном виде:

$$\overline{U_{sij}} = \frac{(\Delta t_{si})}{\max[\Delta t]} \quad (3)$$

где Δt_{si} – среднестатистическое значение простоя атакуемой сети в результате успеха атаки типа *S* посредством *i*-го вектора;

$\max[\Delta t]$ – максимальное значение Δt_{si}.

Таблица 6 – Число упоминаний уязвимостей за 2023 год

Идентификатор уязвимости	Наименование уязвимости
CWE-200	378
CWE-20	1017
CWE-119	365
CWE-400	104
CWE-404	137
CWE-287	148

CWE-306	61
CWE-601	39
CWE-642	1
CWE-918	45
Общее число упоминаний уязвимостей	2294

В рамках данного вектора атаки приведем среднестатистическое время простоя для каждого вектора атаки.

Таблица 7 – Среднестатистическое время простоя для каждой атаки

Вектора атаки	Δt_{si}	$\max[\Delta t]$
VA_1	3,1	18
VA_2	4,3	21
VA_3	1,9	17
VA_4	3,5	9
VA_5	2,7	12

Частота успешного использования уязвимости находится, как отношение числа упоминания данной уязвимости к общему количеству упоминаний всех уязвимостей за исследуемый период. Рассчитаем F_{sij} и $\overline{U_{sij}}$, с использованием данных таблиц 6 и 7. Результаты занесем в таблицы 8 и 9.

Таблица 8 – Значения F_{sij} для уязвимостей

Уязвимость	F_{sij}
CWE-200	0,164777
CWE-20	0,44333
CWE-119	0,159111
CWE-400	0,045335
CWE-404	0,059721
CWE-287	0,064516
CWE-306	0,026591
CWE-601	0,017000
CWE-642	0,000435

CWE-918	0,019616

Таблица 9 - Значения $\overline{U_{sij}}$ для векторов атак

Вектора атаки	$\overline{U_{sij}}$
VA_1	0,1722
VA_2	0,2048
VA_3	0,1118
VA_4	0,3888
VA_5	0,255

Для создания матрицы рисков и риск-ландшафта необходимо разработать матрицу смежности для векторов атак и уязвимостей компьютерными вирусами. При создании матрицы смежности использовались такие источники как CAPEC, MITRE ATT&CK.

Таблица 10 – Матрица смежности сценариев атак и уязвимостей

CWE	VA_1	VA_2	VA_3	VA_4	VA_5
CWE-200	1	1	1	0	0
CWE-20	0	1	0	0	1
CWE-119	0	0	0	0	1
CWE-400	0	0	0	1	1
CWE-404	0	0	0	0	1
CWE-287	0	1	0	0	0
CWE-306	0	1	0	0	0
CWE-601	0	0	1	0	0
CWE-642	1	1	0	0	0
CWE-918	0	0	1	0	0

VA_1: Разведка сети

CWE-200 (Exposure of Sensitive Information): Разведка сети может привести к раскрытию конфиденциальной информации.

CWE-642 (External Control of Critical State Data): Контроль над критическими данными состояния может использоваться для разведки.

VA_2: Определение уязвимых систем

CWE-200 (Exposure of Sensitive Information): Определение уязвимых систем может раскрыть конфиденциальную информацию.

CWE-20 (Improper Input Validation): Определение уязвимостей, связанных с неправильной проверкой входных данных.

CWE-287 (Improper Authentication): Уязвимые системы могут иметь недостаточную проверку подлинности.

CWE-306 (Missing Authentication for Critical Function): Отсутствие проверки подлинности для критических функций.

VA_3: Эксфильтрация данных

CWE-200 (Exposure of Sensitive Information): Эксфильтрация данных напрямую связана с разглашением конфиденциальной информации.

CWE-601 (URL Redirection to Untrusted Site): Использование перенаправления для эксфильтрации данных.

CWE-918 (Server-Side Request Forgery): SSRF может использоваться для эксфильтрации данных.

VA_4: Амплификация трафика

CWE-400 (Uncontrolled Resource Consumption): Амплификация трафика связана с неконтролируемым потреблением ресурсов.

VA_5: Отказ в обслуживании

CWE-20 (Improper Input Validation): Неправильная проверка входных данных может привести к DoS.

CWE-119 (Improper Restriction of Operations within the Bounds of a Memory Buffer): Уязвимости переполнения буфера могут привести к DoS.

CWE-400 (Uncontrolled Resource Consumption): Неконтролируемое потребление ресурсов может привести к DoS.

CWE-404 (Improper Resource Shutdown or Release): Неправильное завершение или освобождение ресурсов может вызвать DoS.

При помощи таблицы 10, с использованием данных из 8 и 9 таблицы и формулы

(2) была составлена таблица номер 11. Данная таблица представляет собой матрицу рисков реализации атак через уязвимости, необходимую для графического отображения риск-ландшафта.

Таблица 11 – Матрица рисков реализации атак через уязвимости

	VA_1	VA_2	VA_3	VA_4	VA_5
CWE-200	0,02837	0,03374	0,01842	0	0
CWE-20	0	0,09079	0	0	0,11304
CWE-119	0	0	0	0	0,04057
CWE-400	0	0	0	0,17626	0,11560
CWE-404	0	0	0	0	0,01522
CWE-287	0	0,01321	0	0	0
CWE-306	0	0,00544	0	0	0
CWE-601	0	0	0,0019006	0	0
CWE-642	0,000075	0,000089	0	0	0
CWE-918	0	0	0,00219	0	0

На основе матрицы рисков реализации атак через уязвимости, был построен Risk-ландшафт. Этот графический инструмент отображает таблицу, содержащую риски, связанные с реализацией атаки методом ICMP Echo Request.

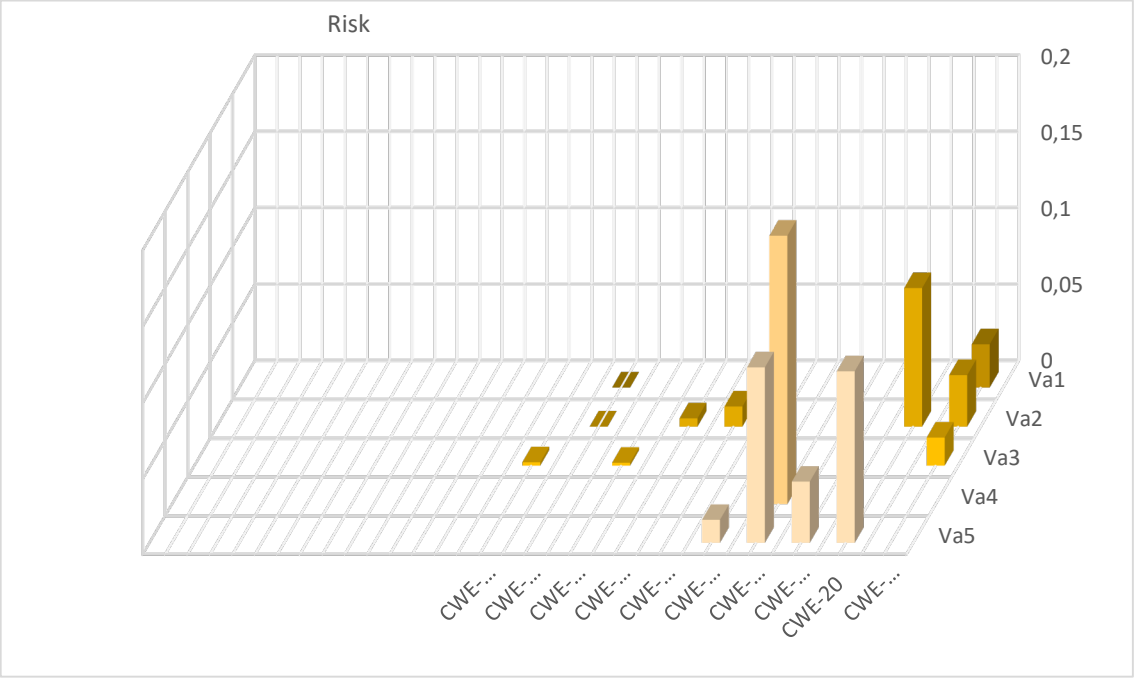


Рис. 5 - Риск-ландшафт реализации атак компьютерными вирусами

Исходя из построенного Risk-ландшафта выделим наиболее опасные сочетания уязвимостей и векторов для компьютерных вирусов.

Таблица 12 - Наиболее опасные сочетания векторов атак и уязвимостей

Идентификатор вектора атаки	Наименование вектора атаки	Идентификатор уязвимости	Наименование уязвимости
VA_1	Разведка сети	CWE-200	Разглашение конфиденциальной информации
		CWE-642	Внешний контроль критических данных состояния
VA_2	Определение уязвимых систем	CWE-200	Разглашение конфиденциальной информации
		CWE-20	Неправильная проверка входных данных
		CWE-287	Недостаточная проверка подлинности
		CWE-306	Отсутствие проверки подлинности для критической функции
VA_3	Эксфильтрация данных	CWE-200	Разглашение конфиденциальной информации
		CWE-601	Перенаправление URL на недоверенный сайт
		CWE-918	Запросы со стороны сервера (SSRF)
VA_4	Амплификация трафика	CWE-400	Неконтролируемое потребление ресурсов
VA_5	Отказ в обслуживании	CWE-20	Неправильная проверка входных данных
		CWE-119	Неправильное ограничение операций в

			пределах буфера памяти
		CWE-400	Неконтролируемое потребление ресурсов
		CWE-404	Неправильное завершение или освобождение ресурсов

Вышеописанная таблица представляет собой сочетание уязвимостей и векторов атак, которые создают наибольший риск при использовании метода ICMP Echo Request. Эти данные будут использованы для дальнейшего исследования и анализа атак.

На основе рассмотренного материала была создана база знаний по атакам, использующим ICMP Echo Request. Этот ресурс будет применяться при разработке частной политики защиты и составлении инструкций для противодействия данным атакам.

2. Частная политика противодействия заданной атаке

2.1. Частные регламенты выявления и регистрации инцидентов нарушения безопасности

Выявление и регистрация инцидентов нарушения безопасности при атаке ICMP Echo Request требуют строгого соблюдения нормативных документов и приказов по информационной безопасности. В основе регламентов лежат ключевые стандарты и требования, такие как ГОСТ Р 57580.1-2017, Приказ ФСТЭК России от 11 февраля 2013 г. N 17, Приказ ФСТЭК России от 21 мая 2013 г. N 31, а также Приказ Минкомсвязи России от 30 сентября 2014 г. N 258. Эти документы устанавливают общие требования к защите информации в различных информационных системах и определяют подходы к обеспечению безопасности (3).

Для выявления атак ICMP Echo Request необходимо организовать постоянный мониторинг сетевой активности с использованием систем обнаружения вторжений (IDS) и систем предотвращения вторжений (IPS) (5). Важным аспектом является настройка мониторинговых систем на фиксацию всех ICMP-запросов, установление пределов для нормального количества запросов и времени их ответа, а также настройка оповещений о подозрительной активности.

Анализ сетевого трафика играет ключевую роль в выявлении атак. Для этого используются инструменты захвата и анализа пакетов, такие как Wireshark. Основные этапы анализа включают захват сетевого трафика в реальном времени, проверку временных меток и частоты ICMP-запросов, а также определение источников подозрительного трафика и их блокировка. Важно учитывать, что атаки могут быть замаскированы под обычный трафик, поэтому анализ аномалий, таких как всплески активности или повторяющиеся запросы с одного и того же IP-адреса, играет критическую роль (4).

После выявления подозрительной активности следует незамедлительно принять меры по ограничению воздействия атаки. Одним из методов является блокировка IP-адресов, с которых исходит подозрительный трафик. Это может быть реализовано с помощью настроек межсетевого экрана (firewall) (5). Важно также уведомить ответственных лиц для проведения дальнейшего расследования и принятия дополнительных мер.

Регистрация инцидентов должна осуществляться в специальной системе учета инцидентов, где фиксируются дата и время обнаружения, описание события, включая количество и частоту ICMP Echo Request, идентификация источника атаки и принятые меры по устранению инцидента. Вся информация о выявленных инцидентах должна быть детально зафиксирована в системе учета. Такой подход обеспечивает прозрачность и позволяет анализировать тенденции в атаках для дальнейшего улучшения мер безопасности.

Обратная связь и уведомления играют важную роль в оперативной реакции на инциденты. Настройка системы оповещения, которая будет уведомлять ответственных лиц о подозрительной активности через email или SMS, обеспечивает своевременное реагирование на угрозы. Регулярные обновления правил и политик безопасности на основе анализа инцидентов позволяют адаптироваться к новым видам атак и повышать уровень защищенности сети.

Для создания эффективного регламента важно включить в него примеры типичных атак и методы их выявления. Это поможет ответственным лицам быстро идентифицировать угрозы и принять необходимые меры. Регламент должен быть легко доступен для всех сотрудников, отвечающих за информационную безопасность, и регулярно обновляться в соответствии с новыми нормативными требованиями и выявленными угрозами (4).

Пример регламента может включать цель и область применения, определение ответственных лиц, процедуры выявления и регистрации, меры реагирования и порядок отчетности. Такой регламент обеспечит комплексный подход к выявлению и регистрации инцидентов, связанных с атаками ICMP Echo Request, и позволит оперативно реагировать на угрозы, минимизируя возможные риски и ущерб для информационной системы.

Таким образом, разработка и внедрение частных регламентов для выявления и регистрации инцидентов нарушения безопасности при атаке ICMP Echo Request на основе нормативных документов и приказов по информационной безопасности обеспечивают комплексный подход к защите сетевых ресурсов. Это позволяет оперативно выявлять и устранять угрозы, минимизируя потенциальный ущерб и повышая общий уровень информационной безопасности в организации (5).\

На основании вышеизложенного, следующим шагом будет создание таблицы объектов защиты. Эта таблица должна включать все элементы информационной системы, подверженные угрозам со стороны ICMP Echo Request атак. Каждый объект защиты должен быть описан с указанием его критичности, уязвимостей, мер защиты и ответственных лиц за его безопасность. Такая таблица поможет систематизировать и упорядочить процесс защиты информационной системы, делая его более прозрачным и эффективным.

Таблица 13 – Объекты защиты

Идентификатор вектора атаки	Сценарий атаки	Объекты защиты
VA_1	1. Отправка ICMP Echo Request для выявления активных узлов в сети.	Маршрутизаторы, коммутаторы, серверы
	2. Определение сетевой топологии путем анализа времени ответа ICMP.	Сетевые устройства
	3. Выявление устройств и сбор дополнительной информации о сетевых устройствах (например, TTL, IP-адреса)	Сетевые карты и коммутаторы
VA_2	1. Отправка ICMP Echo Request для определения, какие устройства отвечают, чтобы выявить уязвимые системы	Серверы, рабочие станции
	2. Анализ времени ответа и характеристик ICMP для определения ОС и версий ПО.	Системы с устаревшими ОС и неправильной конфигурацией
	3. Сканирование устройств на наличие известных уязвимостей через анализ ICMP ответов.	Информационные системы ОС и ПО
	4. Идентификация старых и неисправных систем по отсутствию ответа или специфическим ошибкам.	Устаревшие устройства
VA_3	1. Встраивание конфиденциальных данных в поле данных ICMP Echo Request для скрытой передачи	Конфиденциальные данные
	2. Использование ICMP туннелирования для передачи данных через сеть.	Внутренняя сеть
	3. Маскировка эксфильтрации данных под легитимный ICMP трафик, чтобы обойти системы обнаружения.	Сетевые архивы и системы хранения данных
VA_4	1. Генерация большого количества	Сетевые каналы и

	ICMP Echo Request для увеличения исходящего трафика и перегрузки канала.	маршрутизаторы
	2. Использование ICMP для амплификации трафика через уязвимые устройства, которые отвечают большим объемом данных.	Системы пограничной защиты
	3. Создание условий для усиления трафика и перегрузки сети, направляя запросы на множество узлов.	Защита от перегрузки сетевых устройств
VA_5	1. Отправка большого количества ICMP Echo Request для перегрузки сетевого оборудования и создания отказа в обслуживании.	Веб-серверы, приложения
	2. Создание условий для DoS-атаки через исчерпание ресурсов сети с помощью ICMP запросов.	Системы обнаружения и предотвращения атак (IDS/IPS)
	3. Скоординированная атака с использованием ICMP Echo Request для перегрузки целевой системы.	Устойчивые системы и устройства

Анализируя таблицу, посвященную атакам с использованием ICMP Echo Request, можно выделить несколько ключевых векторов атак. Первый вектор, касается разведки сети. На этом этапе злоумышленник отправляет ICMP Echo Request для выявления активных узлов в сети. Эти запросы позволяют определить, какие устройства находятся в сети и готовы отвечать на запросы, что помогает составить список активных устройств. Затем, анализируя время ответа ICMP, атакующий может понять топологию сети и расположение устройств относительно друг друга. Дополнительно, сбор информации о сетевых устройствах, такой как TTL и IP-адреса, позволяет злоумышленнику составить полную картину сети и определить дальнейшие шаги атаки.

Второй вектор атаки, направлен на определение уязвимых систем. Злоумышленник использует ICMP Echo Request для определения, какие устройства отвечают на запросы, чтобы выявить уязвимые системы. Анализ времени ответа и характеристик ICMP помогает определить операционные системы и версии программного обеспечения на целевых устройствах, что позволяет использовать специфические уязвимости. Сканирование устройств на наличие известных

уязвимостей осуществляется через анализ ICMP ответов, что помогает выявить уязвимые версии программного обеспечения или неисправности в конфигурации системы. Отсутствие ответа или специфические ошибки могут указывать на старые или неисправные системы, что делает их потенциальными целями для дальнейших атак.

Третий вектор атаки, связан с эксфильтрацией данных. Злоумышленник может встраивать конфиденциальные данные в поле данных ICMP Echo Request для скрытой передачи информации через сеть, обходя системы безопасности, которые не проверяют содержимое ICMP пакетов. Также ICMP туннелирование используется для создания виртуального туннеля для скрытой передачи данных. Маскировка эксфильтрации данных под легитимный ICMP трафик помогает обойти системы обнаружения и предотвращения вторжений (IDS/IPS), так как ICMP трафик часто не вызывает подозрений.

Четвертый вектор атаки, направлен на амплификацию трафика. Генерация большого количества ICMP Echo Request увеличивает исходящий трафик и может перегрузить сетевой канал, снижая производительность сети. Злоумышленник также может использовать уязвимые устройства для амплификации трафика, направляя запросы на устройства, которые отвечают большими объемами данных, усиливая атаку. Направление запросов на множество узлов одновременно создает условия для перегрузки сети, что может привести к отказу в обслуживании (DoS) целевых систем.

Пятый вектор атаки, касается отказа в обслуживании. Отправка большого количества ICMP Echo Request приводит к перегрузке сетевого оборудования и отказу в обслуживании (DoS). Системы не справляются с обработкой всех запросов, что снижает доступность сетевых ресурсов. Создание условий для DoS-атаки через исчерпание ресурсов сети осуществляется с помощью постоянных ICMP запросов, что вызывает перегрузку и отказ сетевых устройств. Скоординированные атаки с использованием ICMP Echo Request направлены на перегрузку целевой системы. Эти атаки могут быть частью распределенной DoS-атаки (DDoS), где множество устройств одновременно отправляют запросы, чтобы перегрузить целевые системы и вызвать отказ в обслуживании.

Таким образом, таблица описывает различные сценарии использования ICMP

Echo Request для атак, от разведки сети и определения уязвимых систем до эксфильтрации данных и создания отказа в обслуживании. Каждая из этих атак требует соответствующих мер защиты, таких как использование систем обнаружения и предотвращения атак, правильная конфигурация сетевых устройств и обновление программного обеспечения.

Эта таблица и анализ атак основаны на общепринятых методах классификации и анализа сетевых атак, а также на нормативных документах в сфере информационной безопасности, таких как приказ ФСТЭК России от 11 февраля 2013 года № 17 "Об утверждении Порядка создания системы защиты информации в информационных системах персональных данных". Этот приказ устанавливает требования к защите информации в информационных системах и включает меры по противодействию различным видам сетевых атак, в том числе с использованием ICMP Echo Request (6).

Таблица 14 – Модель нарушителя

Идентификатор нарушителя	Тип нарушителя	Вектор атаки	Уязвимость	Мотивация и цель
M_1	Хакер	VA_1	CWE-200	Мотивация: Финансовая выгода. Цель: Кража банковских данных для получения финансовой прибыли.
M_2	Государственный хакер	VA_2	CWE-200	Мотивация: Шпионаж и промышленный шпионаж. Цель: Получение секретной военной или экономической информации.
M_3	Хакер-этичный взломщик	VA_2	CWE-20	Мотивация: Улучшение безопасности системы. Цель: Обеспечение безопасности системы через тестирование на уязвимости.
M_4	Киберпреступник	VA_3	CWE-200	Мотивация: Финансовая

				мотивация и вымогательство. Цель: Зашифровывание данных и требование выкупа.
M_5	Хактивист	VA_5	CWE-400	Мотивация: Политические убеждения и активизм. Цель: Нарушение работы важных ресурсов для привлечения внимания к проблеме.
M_6	Кибершпион	VA_1	CWE-642	Мотивация: Шпионаж и политические мотивы. Цель: Получение секретной государственной информации.
M_7	Киберпреступник	VA_2	CWE-287	Мотивация: Шпионаж и финансовая мотивация. Цель: Кража финансовых данных для получения выгоды.
M_8	Ботнет	VA_5	CWE-20	Мотивация: Финансовая мотивация. Цель: Организация масштабной DDoS-атаки для нарушения работы онлайн-ресурсов.
M_9	Эксплоитер	VA_2	CWE-306	Мотивация: Получение конфиденциальной информации. Цель: Доступ к конфиденциальной информации через эксплуатацию уязвимостей.
M_{10}	Фишер	VA_1	CWE-200	Мотивация: Кража учетных данных и мошенничество. Цель: Доступ к

				личной информации пользователя для последующего мошенничества.
M_{11}	Рэнсомварщик	VA_3	CWE-601	Мотивация: Финансовая выгода. Цель: Шифрование данных и требование выкупа.
M_{12}	Социальный инженер	VA_1	CWE-642	Мотивация: Манипуляция людьми для получения информации. Цель: Доступ к конфиденциальной информации через социальные уловки.
M_{13}	Киберпреступник	VA_5	CWE-119	Мотивация: Финансовая мотивация. Цель: Эксплуатация переполнения буфера для доступа к системе.
M_{13}	Спаммер	VA_4	CWE-400	Мотивация: Распространение спама для получения выгоды. Цель: Использование ботнетов для рассылки спама.
M_{14}	Вандал	VA_5	CWE-404	Мотивация: Нарушение работы систем из злонамеренности. Цель: Повреждение или уничтожение данных для создания хаоса.
M_{15}	Кибершпион	VA_3	CWE-918	Мотивация: Шпионаж. Цель: Получение конфиденциальных данных через SSRF.

Данная таблица представляет собой систематизированный анализ различных типов кибернарушителей, их методов атак и уязвимостей, а также мотивации и целей. Каждый нарушитель обладает уникальным профилем, который определяет его подход к атаке и выбор вектора атаки. Например, хакеры и киберпреступники часто используют уязвимости, такие как CWE-200 и CWE-20, для получения финансовой выгоды, кражи данных и последующего вымогательства. Их мотивация связана с непосредственным получением прибыли, будь то через кражу банковских данных, учетных записей или шифрование информации с целью получения выкупа.

Государственные хакеры и кибершпионы, напротив, преследуют цели, связанные с шпионажем и получением конфиденциальной информации, имеющей стратегическое значение. Их атаки часто направлены на уязвимости типа CWE-642 и CWE-918, что позволяет им получать доступ к секретной информации, обходя системы безопасности через социальную инженерию или эксплуатацию уязвимостей серверов. Политические и экономические интересы стоят на первом месте в их мотивациях, что делает их действия частью более широких стратегических операций.

Хактивисты и вандалы используют уязвимости, такие как CWE-400 и CWE-404, для привлечения внимания к своим политическим или социальным убеждениям. Их атаки часто носят деструктивный характер, направленные на нарушение работы критически важных ресурсов или создание хаоса. Мотивация этих групп носит идеологический характер, и они стремятся максимизировать публичное внимание к своей деятельности через разрушительные действия, что отличает их от более прагматичных киберпреступников и шпионов.

Наконец, ботнеты и спаммеры представляют собой угрозу, связанную с массовыми атаками, такими как DDoS и рассылка спама, используя уязвимости типа CWE-20 и CWE-400. Их основная цель – это генерация доходов через нелегальные или полулегальные схемы, такие как реклама или вымогательство услуг. Эти атаки часто являются частью более крупной инфраструктуры, где ботнеты используются для создания масштабных деструктивных или мошеннических кампаний.

Для разработки процесса реагирования на инциденты, связанные с атаками ICMP Echo Request, необходимо выделить основные категории инцидентов. Это включает в себя:

1. Инциденты, связанные с обнаружением активности на портах: Такие инциденты часто связаны с ICMP-сканированием, что является первым шагом для выявления активных и уязвимых систем, которые могут быть использованы для проведения атак.
2. Инциденты, относящиеся к эксплуатации уязвимостей системы: Здесь речь, идет о случаях, когда злоумышленники находят и используют уязвимости в системах, такие как CWE-200, CWE-20 и CWE-287, чтобы получить несанкционированный доступ или нарушить работу системы.
3. Инциденты, направленные на эксфильтрацию данных: В этих инцидентах злоумышленники используют уязвимости, такие как CWE-200 и CWE-918, для получения и отправки конфиденциальных данных из целевой системы.
4. Инциденты, связанные с срочной амплификацией (усилением) атак: Такие инциденты включают использование уязвимостей типа CWE-400 для усиления атакующего трафика, что значительно увеличивает объем атак, направленных на истощение ресурсов системы.
5. Инциденты, связанные с простых ресурсов во время атаки (DoS-атаки): Эти инциденты характеризуются тем, что атаки приводят к истощению ресурсов целевой системы через уязвимости, такие как CWE-20, CWE-119 и CWE-404, вызывая отказ в обслуживании и недоступность легитимных сервисов.

Такой подход к классификации инцидентов позволяет лучше понять природу атак и разработать эффективные меры реагирования и защиты.

В следующей таблице 15 представлена классификация инцидентов безопасности по различным категориям, включая описание каждого типа инцидента, его критичность и приоритет. Это поможет определить наиболее важные и критические области для обеспечения безопасности системы.

Таблица 15 – Классификация инцидентов [7, 8]

Идентификатор вектора	Связанные категории инцидента	Описание категории инцидента	Критичность инцидента	Приоритет инцидента
VA_1	Инциденты, связанные с разведкой сети	Такие инциденты связаны с обнаружением и сканированием активных хостов и открытых портов с целью получения информации о сети.	3	Высокий

VA_2	Инциденты, связанные с определением уязвимых систем	Злоумышленники находят и эксплуатируют уязвимости в системах, такие как CWE-200, CWE-20 и CWE-287, чтобы получить несанкционированный доступ или нарушить работу системы.	4	Высокий
VA_3	Инциденты, связанные с эксфильтрацией данных	Злоумышленники используют уязвимости, такие как CWE-200 и CWE-918, для получения и отправки конфиденциальных данных из целевой системы.	5	Высокий
VA_4	Инциденты, связанные с амплификацией трафика	Использование уязвимостей типа CWE-400 для усиления атакующего трафика, что значительно увеличивает объем атак, направленных на истощение ресурсов системы.	4	Средний
VA_5	Инциденты, связанные с отказом в обслуживании (DoS-атаки)	Атаки приводят к истощению ресурсов целевой системы через уязвимости, такие как CWE-20, CWE-119 и CWE-404, вызывая отказ в обслуживании и недоступность легитимных сервисов.	5	Высокий
Все векторы	Инциденты, связанные с обнаружением и реагированием на комплексные атаки, при которых используются различные методы запросов ICMP ECHO Request для нарушения работы сети и сервисов.	Комбинированные атаки, в которых атакующие одновременно применяют различные методы запросов ICMP ECHO Request для нарушения работы сети и сервисов.	5	Высокий

После классификации инцидентов безопасности следующим важным этапом является их обнаружение и регистрация. Эти процессы играют решающую роль в своевременном выявлении угроз, снижении их воздействия и обеспечении устойчивости информационных систем. Без надлежащего обнаружения и регистрации инцидентов, безопасность систем может быть под угрозой, так как незамеченные атаки могут нанести значительный ущерб.

Для эффективного обнаружения инцидентов требуется постоянное наблюдение

за сетевой активностью, анализ логов и применение специализированных инструментов. Использование IDS и IPS позволяет автоматически выявлять аномалии и потенциальные атаки, что значительно повышает скорость реагирования на инциденты. Также важно интегрировать эти системы с другими инструментами безопасности для обеспечения всестороннего мониторинга и защиты.

Документирование инцидентов включает в себя сбор и сохранение информации о природе инцидента, времени его обнаружения, затронутых системах и предпринятых мерах. Это помогает не только оперативно реагировать на текущие угрозы, но и анализировать прошлые инциденты для улучшения политики безопасности. Такой подход позволяет выявлять закономерности и тенденции в инцидентах, что способствует более эффективному предотвращению будущих атак.

Чтобы эффективно обнаруживать и регистрировать инциденты, важно учитывать следующие аспекты:

1. Непрерывное наблюдение за системой: Использование современных инструментов и технологий для постоянного мониторинга сетевой и системной активности.
2. Регулярный анализ логов: Анализ журналов событий для выявления подозрительных действий и аномалий.
3. Автоматизация процессов: Внедрение систем IDS/IPS и SIEM для автоматического обнаружения и корреляции событий.
4. Тщательное документирование: Подробная регистрация всех инцидентов с описанием их характеристик и предпринятых действий.
5. Подготовка и обучение персонала: Обучение сотрудников методам обнаружения и реагирования на инциденты, регулярные тренировки и симуляции.

На основе вышесказанного была составлена таблица 16, которая представляет собой подход к обнаружению и регистрации инцидентов, которые в свою очередь включают в себя основные действия и методы, для эффективного управления инцидентами.

Таблица 16 – Обнаружение и регистрация инцидентов безопасности [8-9]

Типы инцидентов, которые могут возникнуть при реализации действий злоумышленника в ходе сетевой атаки компьютерными вирусами	Описание инцидента	Средства для обнаружения заданного типа инцидента
Разведка сети (VA_1)		
Инциденты, связанные с разведкой сети	Злоумышленники используют ICMP Echo Request для сканирования сети с целью обнаружения активных хостов и открытых портов. Это позволяет получить информацию о структуре сети и подготовиться к дальнейшим атакам.	– IDS/IPS, – сетевые сканеры, – мониторинг трафика, – анализаторы пакетов (Wireshark), SIEM
Определение уязвимых систем (VA_2)		
Инциденты, связанные с определением уязвимых систем	Злоумышленники отправляют ICMP Echo Request к различным системам для определения их состояния и выявления уязвимых узлов. Это может включать проверку наличия ответов от систем с известными уязвимостями или неправильными настройками безопасности.	– Внутренние проверки безопасности, – IDS, – анализ уязвимостей (Nessus, OpenVAS), – сканеры безопасности (Qualys, Rapid7), SIEM
Эксфильтрация данных (VA_3)		
Инциденты, связанные с эксфильтрацией данных	Злоумышленники используют ICMP Echo Request для передачи конфиденциальных данных, маскируя их в ICMP трафике. Это позволяет скрыть передачу данных от систем мониторинга и предотвращения утечек.	– SIEM, DLP (Data Loss Prevention), – сетевые анализаторы, – анализаторы трафика, – IDS/IPS
Амплификация трафика (VA_4)		
Инциденты, связанные с амплификацией трафика	Злоумышленники используют ICMP Echo Request для генерации большого объема трафика, направленного на целевую систему. Это приводит к перегрузке сетевых ресурсов и может	IDS/IPS Анализатор трафика Системы мониторинга сети Фаервол

	вызвать отказ в обслуживании.	Анти-DDoS решения
Отказ в обслуживании (VA_5)		
Инциденты, связанные с отказом в обслуживании (DoS-атаки)	Злоумышленники инициируют DoS-атаки с использованием ICMP Echo Request, отправляя большое количество запросов к серверу, что приводит к его перегрузке и невозможности обработки легитимных запросов.	SIEM IDS/IPS Мониторинг сетевой активности Анти-DDoS решения Балансировщики нагрузки

Для завершения следует подчеркнуть, что эффективное обнаружение и регистрация инцидентов безопасности являются основополагающими элементами обеспечения кибербезопасности. Эти процессы дают организациям возможность быстро реагировать на инциденты, минимизировать ущерб и предотвращать повторение подобных ситуаций в будущем.

Представленные в данной главе регламенты включают подробные инструкции по выявлению и регистрации инцидентов безопасности, а также по последующим действиям. Важно помнить, что их эффективность зависит от регулярного обновления и адаптации к изменяющимся киберугрозам.

В целом, этот раздел выделяет значимость четких регламентов в обеспечении кибербезопасности и готовности к потенциальным инцидентам. Это важный шаг к созданию более безопасного и защищенного цифрового пространства.

2.2. Частные регламенты реагирования на инциденты нарушения безопасности

Частные регламенты реагирования на инциденты нарушения безопасности играют ключевую роль в системе кибербезопасности любой организации. Эти регламенты включают четко определенные процедуры и действия, которые необходимо предпринять в случае обнаружения инцидента. Они направлены на минимизацию последствий атак и обеспечение непрерывности бизнеса. Каждая организация должна разрабатывать собственные регламенты, учитывая свои специфические риски, структуру и ресурсы.

Создание частных регламентов на инциденты нарушения безопасности является комплексным и многоэтапным процессом, требующим участия различных

специалистов и тщательного анализа существующих угроз. Этот процесс можно разделить на несколько ключевых этапов:

Оценка рисков и анализ угроз

Первый шаг в создании регламентов — это оценка рисков и анализ угроз, с которыми может столкнуться организация. Это включает идентификацию всех возможных уязвимостей в системах и сетях, а также потенциальных атакующих и их методов. Для этого используются различные методы, такие как аудит безопасности, тестирование на проникновение (penetration testing) и анализ логов. Оценка рисков помогает понять, какие инциденты наиболее вероятны и могут нанести наибольший ущерб.

Определение целей и задач

На основе анализа угроз и рисков определяются цели и задачи регламентов. Цели включают минимизацию ущерба от инцидентов, быстрое восстановление работы систем и предотвращение повторных атак. Задачи регламентов могут включать детализированные действия по обнаружению, реагированию, восстановлению и документированию инцидентов. На этом этапе важно определить ключевые показатели эффективности (KPI), которые помогут оценить успех выполнения регламентов.

Разработка сценариев инцидентов

Следующий этап — разработка сценариев возможных инцидентов. Это детализированные описания различных типов атак и методов реагирования на них. Сценарии должны учитывать специфику организации и включать конкретные шаги для каждого типа инцидента. Например, сценарии могут описывать действия при обнаружении DoS-атаки, утечки данных или взлома учетных записей. Каждый сценарий должен включать описание инцидента, шаги по его обнаружению, реагированию, восстановлению и документированию.

Создание и документирование регламентов

На основе разработанных сценариев создаются подробные регламенты. Эти документы должны включать все необходимые инструкции и процедуры для реагирования на инциденты. Регламенты должны быть четко структурированы и

легко доступны всем сотрудникам, участвующим в процессе реагирования. Документы должны содержать следующие разделы:

- Определение инцидента и его типы
- Процедуры обнаружения и идентификации инцидентов
- Порядок уведомления заинтересованных сторон
- Шаги по изоляции и устранению угрозы
- Процедуры восстановления систем и данных
- Инструкции по документированию и анализу инцидента

Обучение и тестирование

После создания регламентов необходимо обучить всех сотрудников, ответственных за их выполнение. Это включает проведение тренингов, симуляций и учебных занятий, которые помогут понять и отработать действия в случае реальных инцидентов. Регулярное тестирование регламентов, например, через проведение учений по реагированию на инциденты, позволяет выявить слабые места и внести необходимые коррективы.

Внедрение и мониторинг

Регламенты должны быть внедрены в ежедневную практику организации. Это включает интеграцию регламентов в существующие процессы и системы управления безопасностью. Важно также установить механизмы постоянного мониторинга и аудита выполнения регламентов, чтобы обеспечить их соблюдение и своевременно выявлять любые несоответствия или проблемы.

Обновление и улучшение

Киберугрозы постоянно эволюционируют, поэтому регламенты должны регулярно пересматриваться и обновляться. Это включает анализ новых угроз и уязвимостей, а также оценку эффективности существующих регламентов на основе реальных инцидентов и учений. Обратная связь от сотрудников и результаты аудитов должны использоваться для непрерывного улучшения регламентов.

Эффективное обнаружение и регистрация инцидентов безопасности являются основополагающими элементами обеспечения кибербезопасности. Эти процессы дают организациям возможность быстро реагировать на инциденты, минимизировать возможные убытки и предотвращать повторение подобных ситуаций в будущем.

Представленные в данной главе регламенты предоставляют подробные инструкции по выявлению и регистрации инцидентов безопасности, а также по последующим действиям. Важно помнить, что их эффективность зависит от регулярного обновления и адаптации к изменяющимся киберугрозам.

В общем, данный раздел выделяет значимость четких регламентов в обеспечении кибербезопасности и готовности к потенциальным инцидентам. Это важный шаг к созданию более безопасного и защищенного цифрового пространства.

Основные цели и задачи регламентов:

Основные цели регламентов:

1. **Минимизация ущерба от инцидентов**

- Основная цель регламентов — уменьшить потенциальный ущерб от инцидентов безопасности. Это включает предотвращение потери данных, финансовых убытков, повреждения репутации и других негативных последствий для организации.

2. **Быстрое восстановление работы систем**

- Регламенты направлены на обеспечение быстрого и эффективного восстановления нормальной работы всех систем и процессов после инцидента. Это позволяет минимизировать время простоя и предотвратить длительные перебои в работе.

3. **Предотвращение повторных атак**

- Еще одна важная цель регламентов — предотвратить повторение аналогичных инцидентов в будущем. Для этого проводятся анализ и устранение выявленных уязвимостей, а также обновление и улучшение мер безопасности.

4. **Обеспечение непрерывности бизнеса**

- Регламенты помогают поддерживать непрерывность бизнес-процессов, даже в условиях атак или инцидентов. Это достигается за счет разработки планов действий в чрезвычайных ситуациях и внедрения мер по обеспечению устойчивости систем.

Основные задачи регламентов:

1. **Обнаружение и идентификация инцидентов**

- Разработка процедур и методов для своевременного обнаружения инцидентов безопасности. Это включает использование систем мониторинга, анализ логов и внедрение систем обнаружения вторжений (IDS/IPS).

2. **Классификация и оценка критичности**

- Создание методологии для классификации инцидентов по их типу и степени критичности. Это помогает определить приоритетные действия и необходимые ресурсы для реагирования.

3. **Уведомление заинтересованных сторон**

- Определение порядка уведомления всех заинтересованных сторон о произошедшем инциденте. Это включает внутренние и внешние коммуникации, а также уведомление регуляторов и клиентов, если это необходимо.

4. **Изоляция и устранение угрозы**

- Разработка шагов по изоляции пораженных систем, предотвращению дальнейшего распространения угрозы и устранению уязвимостей. Это может включать временное отключение систем, применение патчей и обновлений безопасности.

5. **Восстановление систем и данных**

- Определение процедур для восстановления работы систем и восстановления утраченных данных. Это включает использование резервных копий, тестирование восстановления и верификацию работоспособности систем.

6. **Документирование и анализ инцидента**

- Ведение подробной документации о каждом инциденте, включая его описание, предпринятые меры и результаты. Проведение анализа инцидента для выявления причин и разработки мер по предотвращению подобных инцидентов в будущем.

7. **Обучение и повышение осведомленности**

- Организация регулярного обучения сотрудников и повышение их осведомленности о методах реагирования на инциденты безопасности. Это включает тренинги, симуляции и распространение информации о текущих угрозах и лучших практиках.

8. **Обновление и улучшение регламентов**

- Регулярное пересмотр и обновление регламентов на основе полученного опыта, новых угроз и изменений в инфраструктуре. Это позволяет поддерживать актуальность и эффективность мер безопасности в организации.

Эти цели и задачи помогают обеспечить комплексный и эффективный подход к управлению инцидентами безопасности, что, в свою очередь, способствует защите информации и стабильности работы организации.

В нашей работе наивысший приоритет отводится инцидентам, связанным с эксфильтрацией данных. Эти инциденты особенно критичны из-за их способности привести к утечке конфиденциальной информации, что может нанести серьезный ущерб репутации и финансовому состоянию организации. Для предотвращения таких инцидентов необходимо внедрение систем управления событиями информационной безопасности (SIEM), использование средств предотвращения утечек данных (DLP), а также настройка сетевых анализаторов, анализаторов трафика и систем обнаружения и предотвращения вторжений (IDS/IPS).

Вторым по приоритетности являются инциденты, связанные с отказом в обслуживании (DoS-атаки). Эти инциденты могут полностью парализовать работу сетевых ресурсов и критически важных систем, что делает их крайне опасными для непрерывности бизнес-процессов. Для предотвращения DoS-атак необходимо наладить работу и поддерживать актуальность систем IDS/IPS, применять анти-DDoS решения, регулярно мониторить сетевую активность через SIEM и использовать балансировщики нагрузки.

Третьими по важности являются инциденты, связанные с обнаружением и реагированием на комплексные атаки, использующие методы запросов ICMP Echo Request. Такие инциденты могут серьезно нарушить работу сетевых сервисов, поэтому для их предотвращения необходимо применять комплексный подход с использованием IDS/IPS, анализаторов протоколов, сетевых сканеров, а также систем мониторинга сети и HIDS.

Четвертый по приоритету отдан инцидентам, связанным с определением уязвимых систем. Эти инциденты могут позволить злоумышленникам получить несанкционированный доступ или нарушить работу системы. Для их предотвращения необходимо регулярно обновлять и патчить уязвимые системы, проводить

внутренние проверки безопасности и использовать инструменты анализа уязвимостей, такие как Nessus, OpenVAS, Qualys и Rapid7.

Пятый приоритет имеют инциденты, связанные с амплификацией трафика. Эти инциденты могут быстро усилить атаку, направленную на истощение ресурсов системы, что делает их опасными в краткосрочной перспективе. Для их предотвращения необходимо своевременное патчение уязвимостей, настройка и обновление IDS/IPS, а также внедрение анти-DDoS решений и анализаторов трафика.

Наименьший приоритет отводится инцидентам, связанным с разведкой сети. Несмотря на свою важность, они обычно не представляют непосредственной угрозы и могут быть предотвращены с помощью настройки и обновления систем IDS/IPS, ограничения доступа к портам и мониторинга трафика.

На основе выше сказанного была построена таблица 17, которая включает в себя категории инцидентов, последовательность реагирования, и первоочередные меры предотвращения.

Таблица 17 - Меры реализации по реагированию на инциденты безопасности

Категория инцидента	Последовательность реагирования	Первоочередные меры предотвращения
Инциденты, связанные с эксфильтрацией данных	1	Внедрение систем управления событиями и предотвращения вторжений (SIEM, IDS/IPS), использование средств предотвращения утечек данных (DLP), настройка сетевых анализаторов и анализаторов трафика
Инциденты, связанные с отказом в обслуживании (DoS-атаки) (VA5)	2	Настройка и поддержание в актуальном состоянии систем IDS/IPS, применение анти-DDoS решений, регулярный мониторинг сетевой активности через SIEM, использование балансировщиков нагрузки
Инциденты, связанные с обнаружением и реагированием на комплексные атаки, использующие методы запросов ICMP Echo Request (Все векторы)	3	Применение комплексного подхода с использованием IDS/IPS, анализаторов протоколов, сетевых сканеров, систем мониторинга сети и HIDS
Инциденты, связанные с определением уязвимых систем (VA2)	4	Регулярное обновление и патчинг уязвимых систем, проведение внутренних проверок безопасности, использование инструментов анализа уязвимостей (Nessus, OpenVAS, Qualys, Rapid7)
Инциденты, связанные с амплификацией трафика (VA4)	5	Своевременное патчение уязвимостей, настройка и обновление IDS/IPS, внедрение анти-DDoS решений и анализаторов трафика
Инциденты, связанные с разведкой сети (VA1)	6	Настройка и обновление систем IDS/IPS, ограничение доступа к портам, мониторинг трафика

В ходе реализации различных типов атак, описанных выше, организация может столкнуться с рядом негативных последствий. Эти последствия могут значительно повлиять на работу компании, её финансовое состояние, репутацию и безопасность данных. Ниже рассмотрены основные негативные последствия, которые могут возникнуть при реализации атак различных типов.

Негативные последствия от утечки конфиденциальной информации могут быть крайне серьезными. Это может включать потерю интеллектуальной собственности, утрату конкурентных преимуществ, нарушение конфиденциальности персональных данных клиентов и сотрудников. Финансовые убытки могут быть связаны с компенсациями, штрафами и потерей доверия клиентов, что в конечном итоге приведет к снижению доходов [8-9].

Атаки типа DoS могут полностью парализовать работу критически важных систем и сервисов, что приведет к простою и снижению производительности. Это может вызвать значительные финансовые потери из-за остановки бизнес-процессов, а также ухудшить репутацию компании среди клиентов и партнеров. Дополнительно, восстановление нормальной работы системы может потребовать значительных временных и материальных затрат.

Комплексные атаки могут существенно нарушить работу сетевых сервисов, затрудняя их обнаружение и реагирование на них. Это может привести к нестабильной работе сети, потере данных и снижению эффективности работы сотрудников. Вдобавок, такие атаки могут открыть дополнительные уязвимости для дальнейших инцидентов [8-9].

Использование уязвимостей в системах может привести к несанкционированному доступу к критическим данным и ресурсам. Злоумышленники могут использовать полученные данные для дальнейших атак, шантажа или продажи на черном рынке. Это также может вызвать утрату доверия со стороны клиентов и партнеров, что негативно скажется на репутации компании.

Инциденты, связанные с амплификацией трафика, могут быстро усилить атаку и привести к перегрузке сетевых ресурсов, что в конечном итоге вызовет отказ в обслуживании. Это может нарушить работу внутренних и внешних сервисов

компании, что приведет к финансовым убыткам и негативным последствиям для клиентов.

Хотя инциденты, связанные с разведкой сети, не всегда несут непосредственную угрозу, они могут предоставить злоумышленникам важную информацию о структуре и уязвимостях сети. Это может стать подготовительным этапом для более серьезных атак, которые в дальнейшем приведут к значительным потерям [8-9].

После рассмотрения о возможных негативных последствиях и реагирования на них, была составлена таблица 18

Таблица 18 - Возможные негативные последствия от инцидентов в ходе реализации атаки

Категория инцидента	Возможные негативные последствия
Инциденты, связанные с эксфильтрацией данных	Потеря конфиденциальной информации, утрата конкурентных преимуществ, финансовые убытки, снижение доверия клиентов
Инциденты, связанные с отказом в обслуживании (DoS-атаки)	Простои и снижение производительности, финансовые потери, ухудшение репутации, затраты на восстановление
Инциденты, связанные с комплексными атаками с использованием ICMP Echo Request	Нестабильная работа сети, потеря данных, снижение эффективности работы сотрудников, дополнительные уязвимости
Инциденты, связанные с определением уязвимых систем	Несанкционированный доступ к критическим данным, использование данных для дальнейших атак, шантаж, утрата доверия клиентов
Инциденты, связанные с амплификацией трафика	Перегрузка сетевых ресурсов, отказ в обслуживании, нарушение работы сервисов, финансовые убытки, негативные последствия для клиентов
Инциденты, связанные с разведкой сети	Предоставление информации о структуре и уязвимостях сети, подготовка к более серьезным атакам, потенциальные значительные потери

Для эффективного противодействия различным видам атак и минимизации их воздействия необходимо внедрение целого ряда конкретных мероприятий и средств защиты. Эти мероприятия должны охватывать все аспекты кибербезопасности, начиная от профилактических мер до оперативного реагирования на инциденты, и включать как технические решения, так и организационные меры.

Первое и основное мероприятие — это внедрение систем управления событиями информационной безопасности (SIEM), систем обнаружения и предотвращения вторжений (IDS/IPS), а также средств предотвращения утечек данных (DLP). SIEM системы позволяют оперативно собирать и коррелировать логи с различных источников, выявлять аномальную активность и реагировать на инциденты в реальном времени. IDS/IPS системы, в свою очередь, анализируют сетевой трафик на наличие известных атак и могут автоматически блокировать подозрительный трафик, предотвращая проникновения. DLP решения помогают защитить конфиденциальные данные от утечек, контролируя перемещение и использование информации в организации.

Кроме этого, необходимо использовать технологии шифрования данных как при передаче, так и при хранении. Шифрование обеспечивает дополнительный уровень защиты конфиденциальной информации, делая её недоступной для злоумышленников даже в случае их успешного проникновения в систему. Также важным элементом является внедрение многофакторной аутентификации (MFA), которая требует от пользователей предоставить несколько доказательств своей личности для доступа к системам и данным.

Второе важное мероприятие — регулярное обновление и патчинг всех систем и приложений. Использование уязвимостей в программном обеспечении — одна из основных тактик злоумышленников. Регулярное применение патчей и обновлений, предоставляемых производителями ПО, позволяет закрыть известные уязвимости и снизить риск их эксплуатации. Необходимо внедрить автоматизированные системы управления патчами, которые обеспечат своевременное обновление всех компонентов ИТ-инфраструктуры. Кроме того, нужно проводить регулярные аудиты безопасности и тестирования на проникновение (penetration testing) для выявления и устранения скрытых уязвимостей.

Третье мероприятие — усиление мониторинга и анализа трафика. Использование современных инструментов для анализа сетевого трафика, таких как анализаторы пакетов (например, Wireshark) и специализированные системы мониторинга, позволяет детально исследовать сетевые взаимодействия и выявлять подозрительную активность. Глубокий анализ пакетов (DPI) помогает обнаружить и заблокировать вредоносный трафик, маскирующийся под легитимные запросы, что особенно важно при борьбе с амплификацией трафика и комплексными атаками.

Четвертое мероприятие — разработка и внедрение четких процедур реагирования на инциденты. Организация должна иметь детально описанные планы действий на случай различных типов инцидентов, включая процедуры обнаружения, реагирования, восстановления и анализа инцидентов. Эти планы должны регулярно обновляться и тестироваться через проведение учений и симуляций. Эффективное реагирование на инциденты требует слаженной работы команды специалистов, поэтому необходимо назначить ответственных за различные аспекты процесса и обеспечить их необходимыми ресурсами и полномочиями.

Пятое мероприятие — обучение и подготовка персонала. Человеческий фактор играет ключевую роль в обеспечении кибербезопасности. Регулярные тренинги и симуляции инцидентов помогут сотрудникам лучше понять методы и техники злоумышленников, а также повысить их готовность к оперативному реагированию на реальные угрозы. Обучение должно охватывать как технические аспекты (например, работа с инструментами безопасности), так и основные принципы информационной безопасности (например, правила создания и использования паролей, распознавание фишинговых атак). Важно также проводить тренировки по управлению инцидентами, включающие взаимодействие всех подразделений организации, чтобы обеспечить их готовность к координированным действиям в случае атаки.

Шестое мероприятие — обеспечение физической безопасности инфраструктуры. Это включает защиту серверных помещений, центров обработки данных и других критических объектов от несанкционированного доступа. Необходимо использовать системы контроля доступа, видеонаблюдение, а также обеспечивать защиту от пожаров и других чрезвычайных ситуаций. Физическая безопасность является неотъемлемой частью общей стратегии кибербезопасности,

так как физическое проникновение в инфраструктуру может дать злоумышленникам доступ к ключевым системам и данным.

Эти мероприятия в совокупности помогут создать многослойную защиту, которая значительно повысит устойчивость организации к различным видам кибератак и минимизирует потенциальные негативные последствия. Кибербезопасность — это не статичный процесс, а постоянно развивающаяся область, требующая регулярного обновления знаний и технологий, адаптации к новым угрозам и постоянного совершенствования процессов и процедур. Только комплексный и системный подход позволит эффективно защищать организацию от современных киберугроз.

Таблица 19 – Мероприятия по противодействию атаке

№ п/п	Мероприятия по противодействию сетевой атаки	Срок исполнения	Дополнительные мероприятия
1	Внедрение и настройка систем IDS/IPS	Незамедлительно	Постоянный мониторинг сетевого трафика и обновление сигнатур
2	Настройка правил файрвола для фильтрации ICMP трафика	Незамедлительно	Ограничение ICMP Echo Request на внешних интерфейсах
3	Обновление и патчинг сетевых устройств и программного обеспечения	30 дней	Использование автоматизированных систем управления патчами
4	Внедрение многофакторной аутентификации (MFA)	Незамедлительно	Обучение сотрудников безопасному использованию учетных данных
5	Регулярные аудиты безопасности и анализ сетевого трафика	30 дней	Проведение тестирования на проникновение
6	Разработка и тестирование планов реагирования на инциденты (IRP)	60 дней	Проведение регулярных учений и симуляций инцидентов
7	Внедрение шифрования данных при передаче	30 дней	Регулярное обновление ключей шифрования
8	Ограничение доступа к критическим системам и сегментация сети	Незамедлительно	Регулярное обновление ключей шифрования
9	Использование систем предотвращения утечек данных (DLP)	30 дней	Контроль использования внешних устройств и облачных сервисов

10	Постоянное обучение сотрудников по вопросам кибербезопасности	30 дней	Проведение курсов повышения квалификации и тренингов

В заключение, частные регламенты реагирования на инциденты нарушения безопасности играют ключевую роль в общей стратегии обеспечения кибербезопасности организации. Эти регламенты включают в себя детализированные процедуры и меры, которые позволяют эффективно обнаруживать, реагировать и восстанавливаться после различных типов инцидентов. Благодаря четко прописанным инструкциям и регулярным обновлениям, организации могут значительно снизить время реагирования на угрозы, минимизировать ущерб и предотвращать повторение аналогичных инцидентов в будущем.

Эффективность частных регламентов во многом зависит от их адаптации к специфике организации и актуальным киберугрозам. Важно, чтобы данные регламенты были интегрированы в общую систему управления информационной безопасностью, включали регулярное обучение персонала, использование современных технологий защиты и проведение регулярных тестирований и учений. Такой подход позволяет создавать многослойную защиту, которая значительно повышает устойчивость кибератак и обеспечивает непрерывность бизнес-процессов.

В целом, разработка и внедрение частных регламентов реагирования на инциденты является важным шагом на пути к созданию безопасной и устойчивой к угрозам информационной инфраструктуры. Это не только помогает защитить конфиденциальную информацию и критические ресурсы, но и способствует повышению доверия со стороны клиентов и партнеров, укрепляя репутацию организации на рынке.

2.3. Частные регламенты ликвидации последствий инцидентов нарушения безопасности

Ликвидация последствий инцидентов нарушения безопасности — это ключевой аспект кибербезопасности, направленный на восстановление нормальной работы систем и минимизацию ущерба после произошедшего инцидента. Частные

регламенты ликвидации последствий предоставляют четкие инструкции и процедуры, необходимые для эффективного восстановления и предотвращения повторения аналогичных инцидентов в будущем.

Для каждой организации важно иметь четкий и детализированный план ликвидации последствий инцидентов. Такой план должен включать в себя основные этапы реагирования, методы восстановления систем, а также мероприятия по предотвращению повторных инцидентов. В этой главе мы рассмотрим основные этапы и ключевые мероприятия, необходимые для успешной ликвидации последствий инцидентов, а также представим схему создания частных регламентов ликвидации последствий инцидентов нарушения безопасности.

Переходя к разработке частных регламентов ликвидации последствий инцидентов, необходимо учитывать несколько важных аспектов. Во-первых, регламенты должны быть адаптированы под конкретные условия и специфику деятельности организации. Во-вторых, они должны включать четкие инструкции и быть легко применимыми на практике. И наконец, регулярное обновление и тестирование этих регламентов обеспечивает их актуальность и эффективность в условиях быстро меняющегося ландшафта киберугроз.

Процесс создания частных регламентов ликвидации последствий инцидентов включает несколько ключевых этапов, которые необходимо тщательно планировать и координировать. На основе информации из ГОСТ Р 59712-2022 и ГОСТ Р ИСО/МЭК ТО 18044-2007 можно выделить следующие этапы [12][13]:

1. Оценка рисков и текущего состояния безопасности
- Проведение анализа текущих мер безопасности и выявление уязвимостей.
- Определение критически важных активов и систем, которые могут быть затронуты инцидентом.
- Приоритизация рисков на основе их вероятности и потенциального воздействия.
2. Формирование команды реагирования на инциденты (CSIRT)
- Назначение членов команды из различных отделов, включая ИТ, юридический отдел, отдел связей с общественностью и кадровую службу.
- Определение ролей и обязанностей каждого члена команды.

- Обеспечение доступа команды к необходимым ресурсам и полномочиям для принятия быстрых решений.

3. Разработка процедур реагирования и ликвидации последствий

- Создание детализированных пошаговых инструкций для каждого этапа реагирования на инциденты, включая идентификацию, изоляцию, устранение и восстановление.
- Установление четких каналов и протоколов коммуникации для взаимодействия внутри команды и с внешними партнерами.

4. Обучение и подготовка персонала

- Проведение тренингов и симуляций инцидентов для проверки готовности сотрудников.
- Обучение сотрудников методам ликвидации последствий инцидентов и выполнению плана восстановления.

5. Тестирование и обновление регламентов

- Регулярное проведение тестирований и учений для проверки актуальности и эффективности регламентов.
- Обновление регламентов на основе результатов тестов и анализа инцидентов.

6. Документирование и анализ инцидентов

- Ведение подробной документации всех инцидентов и предпринимаемых действий.
- Проведение анализа причин инцидентов и разработка мер для предотвращения их повторения.

Цели частных регламентов ликвидации последствий инцидентов:

1. Снижение ущерба. Регламенты ориентированы на оперативное и эффективное устранение последствий инцидентов, что позволяет минимизировать ущерб для компании.
2. Восстановление нормальной работы. Основная цель заключается в как можно более быстром восстановлении нормального функционирования систем и сервисов после инцидента.

3. Улучшение мер безопасности. Каждый инцидент предоставляет возможность для улучшения существующих мер безопасности и предотвращения подобных ситуаций в будущем.
4. Обучение и подготовка персонала. Регламенты включают обучение и подготовку сотрудников для эффективного реагирования на инциденты.

Следущая схема ликвидации последствий компьютерного инцидента разработана на основе российских стандартов и нормативных документов, включая ГОСТ Р 57580.1-2017 «Защита информации. Основные меры защиты информации, требуемые для выполнения требований Федерального закона № 152-ФЗ "О персональных данных"», Приказ ФСТЭК России от 11 февраля 2013 г. № 17 «Об утверждении требований к обеспечению защиты персональных данных при их обработке в информационных системах персональных данных», а также ГОСТ Р 50922-96 «Защита информации. Основные термины и определения». Данная схема предназначена для организаций, стремящихся обеспечить эффективное реагирование на компьютерные инциденты, минимизировать ущерб и предотвратить повторение подобных ситуаций в будущем [14][15][16] .

1. Обнаружение инцидента

- Активный мониторинг и анализ аномалий:
    - Использование автоматизированных систем мониторинга.
    - Применение методов машинного обучения и анализа поведения.
- Подача сигналов и уведомление о инциденте**:**
    - Системы автоматического оповещения ответственных лиц.
    - Четкое определение критериев инцидента и его приоритетов.
- Первоначальные меры реагирования
- Изоляция пострадавших систем:
    - Отключение от сети пострадавших устройств.
    - Блокировка скомпрометированных учетных записей.
- Сбор первичной информации:
    - Сохранение логов и создание копий данных для дальнейшего анализа.
    - Проведение первичного анализа для определения характера инцидента.
- Анализ и оценка инцидента

- Технический анализ:
    - Определение источника и методов атаки.
    - Анализ вредоносного ПО и других признаков компрометации.
- Оценка ущерба и рисков:
    - Определение объема утечек данных и пострадавших систем.
    - Оценка потенциальных последствий для бизнеса и клиентов.
- Ликвидация последствий
- Восстановление систем и данных:
    - Восстановление данных из резервных копий.
    - Переустановка и настройка скомпрометированных систем.
- Устранение уязвимостей:
    - Установка патчей и обновлений.
    - Проведение аудита безопасности и внедрение дополнительных мер защиты.
- Постинцидентные действия
- Документирование инцидента:
    - Создание отчета по результатам инцидента.
    - Включение всех этапов, от обнаружения до ликвидации.
- Анализ и улучшение:
    - Проведение посмертного анализа (Post-Mortem).
    - Обновление планов реагирования и политик безопасности на основе полученных данных.
- Информирование заинтересованных сторон:
    - Уведомление клиентов и партнеров о произошедшем инциденте и принятых мерах.
    - Сотрудничество с государственными органами и выполнение требований законодательства.

Инциденты, связанные с разведкой сети. При обнаружении инцидента, связанного с разведкой сети, необходимо немедленно изолировать подозрительную активность. Это включает в себя блокировку IP-адресов, с которых были замечены попытки сканирования сети, и усиление мониторинга для выявления дальнейших

подозрительных действий. Важно также обновить правила файервола и IDS/IPS для предотвращения повторных попыток разведки. Анализ логов и сетевого трафика поможет определить источники и цели сканирования, что позволит предпринять дополнительные меры для защиты критических систем и данных.

Инциденты, связанные с определением уязвимых систем. В случае инцидента, связанного с определением уязвимых систем, следует провести полную инвентаризацию всех активов, чтобы выявить и изолировать уязвимые системы. После изоляции необходимо провести оперативное обновление всех уязвимых программных и аппаратных компонентов. Параллельно с этим нужно провести анализ логов для определения источника атаки и методов, использованных злоумышленниками. Рекомендуется также провести полный аудит безопасности для выявления других потенциальных уязвимостей и повышения уровня защиты.

Инциденты, связанные с эксфильтрацией данных. При выявлении эксфильтрации данных критически важно немедленно остановить утечку информации. Для этого следует изолировать скомпрометированные системы и блокировать подозрительные учетные записи. Затем необходимо провести детальный анализ логов и сетевого трафика для определения объема утечки и пути, по которому данные были переданы. Восстановление данных из резервных копий и уведомление пострадавших сторон о произошедшем инциденте также являются важными шагами. После устранения инцидента следует провести аудит безопасности и внедрить дополнительные меры для предотвращения повторных утечек.

Инциденты, связанные с амплификацией трафика. В случае инцидента, связанного с амплификацией трафика, необходимо оперативно настроить фильтрацию трафика на сетевом уровне для блокировки вредоносных запросов. Использование технологий анти-DDoS и настройка ограничений на уровне файервола помогут снизить воздействие атаки. После купирования инцидента следует провести анализ источников трафика и методов амплификации, чтобы внести коррективы в существующие защитные механизмы и предотвратить аналогичные инциденты в будущем.

Инциденты, связанные с отказом в обслуживании (DoS-атаки). При инциденте, связанном с DoS-атакой, важно быстро идентифицировать и заблокировать

источники атакующего трафика. Настройка анти-DDoS решений и использование технологий балансировки нагрузки помогут минимизировать влияние атаки на работу сервисов. Важно также провести анализ логов и сетевого трафика для понимания масштаба и методов атаки. После ликвидации инцидента рекомендуется пересмотреть архитектуру сети и внедрить дополнительные меры защиты, такие как распределение нагрузки и резервирование критических ресурсов.

Инциденты, связанные с обнаружением и реагированием на комплексные атаки, при которых используются различные методы запросов ICMP ECHO Request для нарушения работы сети и сервисов. В случае комплексных атак, использующих ICMP ECHO Request, необходимо настроить фильтрацию и ограничение ICMP-трафика на уровне сети и отдельных хостов. Использование сетевых экранов и систем обнаружения вторжений (IDS/IPS) поможет выявить и блокировать подозрительные запросы. Также важно провести анализ трафика для определения источников атаки и оценки ущерба. После устранения инцидента следует пересмотреть настройки сетевой безопасности и внедрить дополнительные меры защиты, такие как сегментация сети и улучшение мониторинга сетевого трафика

На основе вышеизложенной информации и российских нормативных документов, включая ГОСТ Р 57580.1-2017, Приказ ФСТЭК России от 11 февраля 2013 г. № 17, и ГОСТ Р 50922-96, была составлена таблица, в которой представлены основные категории компьютерных инцидентов, возможные негативные последствия и план по их ликвидации. Эта таблица поможет систематизировать подход к ликвидации последствий различных типов компьютерных инцидентов и повысить уровень информационной безопасности в организации.

Таблица 20 – План мероприятий по противодействию атаке типа «ICMP ECHO Request»[14][15][16]

Категория инцидента	Возможные негативные последствия	План по ликвидации
Инциденты, связанные с разведкой сети	Утечка информации о топологии сети, системах и службах; возможность проведения последующих атак	Изолировать подозрительную активность; блокировать IP-адреса источников; обновить правила файервола и IDS/IPS; анализ логов и трафика
Инциденты, связанные с	Увеличение риска атак на	Провести инвентаризацию активов;

определением уязвимых систем	уязвимые системы; возможность эксплуатации уязвимостей	изолировать уязвимые системы; оперативно обновить ПО и оборудование; анализ логов; аудит безопасности
Инциденты, связанные с эксфильтрацией данных	Утечка конфиденциальных данных; ущерб репутации; финансовые потери	Немедленно остановить утечку; изолировать скомпрометированные системы; блокировать подозрительные учетные записи; анализ логов и трафика; восстановление данных; уведомление пострадавших сторон
Инциденты, связанные с амплификацией трафика	Нарушение работы сети и сервисов; увеличение нагрузки на ресурсы	Настроить фильтрацию трафика; использовать анти-DDoS решения; анализ источников и методов амплификации; корректировка защитных механизмов
Инциденты, связанные с отказом в обслуживании (DoS-атаки)	Нарушение доступности сервисов; отказ в обслуживании пользователей	Идентифицировать и заблокировать источники атакующего трафика; настроить анти-DDoS решения; анализ логов и трафика; пересмотр архитектуры сети; внедрение дополнительных мер защиты
Инциденты, связанные с обнаружением и реагированием на комплексные атаки, при которых используются различные методы запросов ICMP ECHO Request для нарушения работы сети и сервисов.	Нарушение работы сети и сервисов; увеличение нагрузки на инфраструктуру	Идентифицировать и заблокировать источники атакующего трафика; настроить анти-DDoS решения; анализ логов и трафика; пересмотр архитектуры сети; внедрение дополнительных мер защиты

Для более полного понимания и предотвращения инцидентов важно также рассмотреть причины и условия их возникновения. Следующая таблица представляет собой обзор основных причин и условий, способствующих возникновению инцидентов безопасности.

Таблица 21 – Причины и условия возникновения инцидентов безопасности

Категория инцидента	Причины и условия возникновения инцидентов безопасности
Инциденты, связанные с разведкой сети	Недостаточная настройка сетевых экранов и IDS/IPS; отсутствие мониторинга сетевого трафика; низкая осведомленность сотрудников о методах социальной инженерии.
Инциденты, связанные с определением уязвимых систем	Использование устаревших версий программного обеспечения; недостаточное применение патчей и обновлений; неправильная конфигурация систем безопасности.
Инциденты, связанные с эксфильтрацией данных	Недостаточные меры по защите данных; слабая аутентификация и контроль доступа; использование нешифрованных каналов передачи данных; отсутствие мониторинга и логирования действий пользователей.
Инциденты, связанные с амплификацией трафика	Неправильная настройка сетевых устройств и серверов; отсутствие средств защиты от DDoS-атак; недостаточный контроль за сетевым трафиком.
Инциденты, связанные с отказом в обслуживании (DoS-атаки)	Недостаточная защита инфраструктуры от высоких нагрузок; отсутствие балансировки нагрузки; неадекватная настройка сетевых экранов и анти-DDoS решений.
Инциденты, связанные с обнаружением и реагированием на комплексные атаки, при которых используются различные методы запросов ICMP ECHO Request для нарушения работы сети и сервисов.	Отсутствие ограничений и фильтрации ICMP-трафика; недостаточная сегментация сети; неправильная настройка сетевых экранов и IDS/IPS; отсутствие постоянного мониторинга и анализа сетевого трафика.

Эта таблица позволяет систематизировать и понять основные причины и условия, приводящие к возникновению инцидентов безопасности, что помогает в разработке и внедрении превентивных мер для минимизации рисков.

В данной главе был рассмотрен процесс ликвидации последствий различных типов инцидентов нарушения безопасности, основанный на российских стандартах и нормативных документах, включая ГОСТ Р 57580.1-2017, Приказ ФСТЭК России от 11 февраля 2013 г. № 17, и ГОСТ Р 50922-96. Мы систематизировали подходы к ликвидации инцидентов, таких как разведка сети, определение уязвимых систем, эксфильтрация данных, амплификация трафика, отказ в обслуживании (DoS-атаки) и комплексные атаки с использованием ICMP ECHO Request.

На основе представленных данных была составлена таблица, включающая категории инцидентов, возможные негативные последствия и план по их ликвидации. Эта таблица является важным инструментом для систематизации и структурирования

мероприятий по реагированию на инциденты, что способствует повышению уровня информационной безопасности в организации.

Также была рассмотрена таблица причин и условий возникновения инцидентов безопасности, что позволило глубже понять механизмы возникновения различных инцидентов и разработать превентивные меры для их предотвращения.

Таким образом, частные регламенты ликвидации последствий инцидентов нарушения безопасности являются неотъемлемой частью системы обеспечения информационной безопасности. Они помогают минимизировать ущерб от инцидентов, повышают готовность организаций к реагированию на угрозы и способствуют созданию более защищенной информационной среды.

3. Частные инструкции для противодействия рассматриваемой атаке

Атаки, использующие метод ICMP ECHO Request, представляют собой серьёзную угрозу для информационных систем и сетей организаций. Эти атаки направлены на создание большого объема сетевого трафика посредством протокола ICMP, что может привести к перегрузке серверов и отказу в обслуживании (DoS). Для успешного противодействия таким атакам необходимо применять современные методы и инструменты сетевой безопасности, а также соблюдать соответствующие стандарты и нормативы.

Для эффективного управления информационной безопасностью требуется тщательное понимание механизмов угроз и способов их нейтрализации. Российские стандарты, такие как ГОСТ Р 50922-96 «Защита информации. Основные термины и определения», ГОСТ Р ИСО/МЭК 27001-2012 «Информационная технология. Методы и средства обеспечения безопасности. Системы менеджмента информационной безопасности. Требования» и ГОСТ Р 56518-2015 «Информационная технология. Безопасность информационных технологий. Рекомендации по управлению информационной безопасностью», указывают на необходимость разработки и внедрения специальных инструкций для борьбы с конкретными угрозами.

Администраторы сетевой безопасности должны обладать четким пониманием функциональных знаний и навыков, необходимых для защиты сетей организации от атак ICMP ECHO Request. В этой главе рассматриваются основные аспекты, которые следует учитывать при создании таких инструкций. Также представлена таблица, систематизирующая ключевые навыки и умения для успешной защиты сетевой инфраструктуры.

Первым шагом в защите сети является идентификация потенциальных уязвимостей с помощью сетевого сканирования. Администраторы должны знать принципы работы сетевых сканеров, таких как Nmap и Wireshark, и уметь применять эти инструменты на практике. Это включает настройку и использование данных инструментов для обнаружения аномалий и анализа сетевого трафика.

Методы обнаружения при сканировании позволяют заблаговременно выявлять попытки атак и предпринимать необходимые меры для их предотвращения. Важно,

чтобы администраторы умели анализировать данные сетевого трафика и выявлять подозрительную активность.

Для предотвращения атак ICMP ECHO Request необходимо понимать принципы уязвимостей и способы их эксплуатации. Администраторы должны уметь использовать инструменты для обнаружения уязвимостей, такие как Nessus и OpenVAS, а также своевременно применять патчи и обновления для их устранения.

Регулярное обновление программного обеспечения и патчинг являются ключевыми аспектами защиты информационных систем. Несвоевременное обновление может привести к эксплуатации уязвимостей злоумышленниками.

Маскировка трафика является одной из техник, используемых злоумышленниками для обхода систем защиты. Администраторы должны обладать знаниями о методах обфускации и шифрования трафика, а также сетевых протоколов для анализа сетевого трафика на предмет аномалий и подозрительной активности.

Применение инструментов, таких как Wireshark и tcpdump, позволяет эффективно обнаруживать и анализировать зашифрованный трафик, что помогает в предотвращении скрытых атак.

Атаки с амплификацией трафика создают большой объем данных, приводящий к перегрузке сетей и серверов. Администраторы должны понимать принципы DDoS-атак и методы амплификации трафика, а также использовать средства защиты, такие как Cloudflare и Arbor Networks.

Анализ сетевого трафика на предмет аномалий и настройка защитных механизмов позволяет эффективно противостоять атакам с амплификацией трафика.

Отказ в обслуживании является одной из наиболее распространённых форм атак. Знание принципов DoS-атак и методов их проведения позволяет администраторам более эффективно защищать системы и сети.

Настройка и использование средств защиты от DoS-атак, таких как Cloudflare и Arbor Networks, а также регулярный анализ сетевого трафика на предмет аномалий, помогают предотвращать и минимизировать последствия таких инцидентов.

Для наглядного представления необходимых знаний и умений администратора, ответственного за защиту сетевой инфраструктуры от атак с использованием метода

ICMP ECHO Request, на основе ранее упомянутых документов была разработана таблица под номером 22.

Таблица 22 - Способность разрабатывать и внедрять стратегии восстановления после атак

Функциональные знания Администратора, которыми он должен обладать, чтобы успешно защитить сеть Организации	Требования к умениям Администратора, которыми он должен владеть, чтобы успешно защищать сеть Организации
Разведка сети (VA_1)	
Знание методов сетевого сканирования и обнаружения	Умение использовать инструменты сетевого сканирования, такие как Nmap и Wireshark
	Способность анализировать сетевые карты и выявлять потенциальные угрозы
Определение уязвимых систем (VA_2)	
Понимание принципов работы уязвимостей и методов их эксплуатации	Способность применять инструменты для обнаружения уязвимостей, такие как Nessus и OpenVAS
	Умение выполнять тестирование на проникновение для выявления слабых мест
Эксфильтрация данных (VA_3)	
Знание протоколов и методов защиты данных	Умение анализировать сетевой трафик и выявлять аномалии
	Способность настраивать системы мониторинга для обнаружения утечек данных
Амплификация трафика (VA_4)	
Понимание принципов амплификации трафика и DDoS-атак	Способность настраивать и использовать средства защиты, такие как Cloudflare и Arbor Networks
	Умение идентифицировать и смягчать DDoS-атаки с использованием различных методик
Отказ в обслуживании (VA_5)	
Знание принципов работы DoS-атак и методов их предотвращения	Умение анализировать и предотвращать DoS-атаки, а также использовать защитные средства
	Способность разрабатывать и внедрять стратегии восстановления после атак

Для достижения надежной защиты информационных систем от разнообразных векторов атак недостаточно ограничиваться только теоретическими знаниями и пониманием сетевых и системных уязвимостей. Практическое применение этих знаний с использованием конкретных средств защиты информации и их правильной настройки имеет решающее значение. В предыдущей таблице рассмотрены ключевые функциональные знания и требования к умениям администратора, необходимые для защиты сетей. Тем не менее, для более глубокого понимания практических шагов следует изучить конкретные планы действий администратора при выборе и настройке средств защиты информации.

Ключевыми инструментами обеспечения безопасности являются средства защиты информации (СЗИ), такие как межсетевые экраны, системы обнаружения и

предотвращения вторжений, системы глубокого анализа трафика и решения для защиты от DDoS-атак. Их правильный выбор и настройка имеют критическую важность для обеспечения надежной защиты информационных систем.

Данные, использованные для создания следующей таблицы, были взяты с официального сайта Федеральной службы по техническому и экспортному контролю (ФСТЭК). Таблица включает основные вектора атак, требования к защите информации от этих атак, соответствующие средства защиты информации и рекомендации по их настройке. Эта информация будет полезна администраторам при планировании и реализации мер по обеспечению безопасности информационных систем [14].

При разработке и внедрении систем защиты информации необходимо учитывать требования российских государственных стандартов, которые регламентируют различные аспекты информационной безопасности:

1. ГОСТ Р 57580.1-2017 "Безопасность финансовых (банковских) операций. Защита информации финансовых организаций. Основные положения" – этот стандарт определяет основные требования к защите информации в финансовых учреждениях, включая меры по предотвращению несанкционированного доступа и атак
2. ГОСТ Р 56939-2016 "Информационная безопасность. Защита информации. Основные термины и определения" – стандарт включает основные термины и определения, используемые в области защиты информации, что способствует стандартизации и унификации терминологии.
3. ГОСТ Р 58178-2018 "Информационные технологии. Безопасность информационных технологий. Руководство по обеспечению информационной безопасности для организаций" – предоставляет руководство по реализации мер информационной безопасности в организациях, включая методы выявления и регистрации инцидентов.
4. ГОСТ Р 52633.5-2011 "Автоматизированные системы. Защита от несанкционированного доступа к информации. Классификация автоматизированных систем и требования по защите информации" – этот стандарт классифицирует автоматизированные системы по уровню защиты

информации и устанавливает требования к ним.

В следующей таблице 23 «Пример плана действий Администратора при выборе и настройке» будут систематизированы ключевые векторы атак, требования к защите информации от атак компьютерными вирусами, конкретные средства защиты информации, обеспечивающие выполнение этих требований, а также рекомендации по настройке параметров данных средств защиты.

В данной таблице будут рассмотрены следующие векторы атак:

1. Разведка сети.
2. Определение уязвимых систем.
3. Эксфильтрация данных.
4. Амплификация трафика.
5. Отказ в обслуживании (DoS-атаки).

Для каждого из перечисленных векторов будут указаны требования к защите, соответствующие средства защиты и рекомендации по их настройке. Основными документами, регламентирующими меры и требования к информационной безопасности, являются ГОСТ Р 50922-96 «Защита информации. Основные термины и определения», ГОСТ Р ИСО/МЭК 27001-2021 «Информационная технология. Методы и средства обеспечения безопасности. Системы менеджмента информационной безопасности. Требования» и ГОСТ Р 56518-2015 «Информационная технология. Безопасность информационных технологий. Рекомендации по управлению информационной безопасностью».

Таблица 23 - Пример плана действий Администратора сетевой безопасности при выборе и настройке СЗИ [16][17]

Требование к защите информации от атаки компьютерными вирусами	Средство защиты информации, обеспечивающие выполнение данных требований	Рекомендация по настройке параметров средств защиты информации
Сканирование сети (VA_1)		
Предотвращение несанкционированного сканирования сети и открытых портов	Nmap 7.91, Wireshark 3.4.2, Cisco Firepower 7.0	Настроить сетевые сканеры для регулярного мониторинга активности. Установить правила блокировки для подозрительных IP-адресов. Включить автоматические уведомления об аномалиях.
Обнаружение и эксплуатация уязвимостей (VA_2)		

Обнаружение и устранение уязвимостей, регулярное обновление ПО	Nessus 8.13, OpenVAS 21.4.3, Qualys 10.0	Регулярно сканировать системы на наличие уязвимостей. Настроить автоматическое обновление систем безопасности. Создать расписание для проведения еженедельных проверок.
Маскировка трафика (VA_3)		
Защита данных от несанкционированного доступа и утечек	Symantec DLP 15.7, McAfee DLP 11.6, VeraCrypt 1.24	Внедрить шифрование для всех критичных данных. Настроить DLP системы для мониторинга и блокировки подозрительных передач данных. Создать правила для автоматического уведомления о попытках утечки данных.
Амплификация трафика (VA_4)		
Предотвращение использования амплификации для усиления атак	Cloudflare 2021, Arbor Networks APS 5.0, Radware DefensePro 8.13	Настроить системы защиты от DDoS для автоматической блокировки аномального трафика. Включить регулярный анализ трафика для выявления аномалий. Настроить автоматические отчеты о состоянии системы.
Отказ в обслуживании (VA_5)		
Обеспечение устойчивости системы к DoS-атакам	Cloudflare 2021, Akamai Kona Site Defender 2021, Arbor Networks APS 5.0	Внедрить балансировщики нагрузки для равномерного распределения трафика. Настроить системы для автоматической идентификации и блокировки DoS-атак. Включить функции мониторинга и отчетности о всех инцидентах.

Так же рассмотрим пример плана действий Инженер по безопасности при выборе и настройке СЗИ.

Таблица 23 - Пример плана действий Администратора сетевой безопасности при выборе и настройке СЗИ [16][17]

Требование к защите информации от атаки компьютерными вирусами	Средство защиты информации, обеспечивающие выполнение данных требований	Рекомендация по настройке параметров средств защиты информации
Сканирование сети (VA_1)		
Предотвращение несанкционированного сканирования сети и открытых портов	Nmap 7.91, Wireshark 3.4.2, Cisco Firepower 7.0	Инженеру по безопасности следует использовать Nmap для детального картографирования сети и выявления всех активных устройств. Wireshark поможет в глубокого анализа пакетов, чтобы выявить подозрительную активность. Cisco Firepower необходимо настроить для автоматической блокировки известных угроз и интеграции с SIEM для детального мониторинга.
Обнаружение и эксплуатация уязвимостей (VA_2)		

Обнаружение и устранение уязвимостей, регулярное обновление ПО	Nessus 8.13, OpenVAS 21.4.3, Qualys 10.0	Инженер должен организовать комплексную программу управления уязвимостями, используя Nessus для регулярных проверок и OpenVAS для непрерывного мониторинга. Qualys следует настроить для автоматического выявления и устранения уязвимостей. Все результаты сканирования должны интегрироваться с системой управления инцидентами (ITSM) для дальнейшего анализа
Маскировка трафика (VA_3)		
Защита данных от несанкционированного доступа и утечек	Symantec DLP 15.7, McAfee DLP 11.6, VeraCrypt 1.24	Инженер по безопасности должен настроить комплексное шифрование данных на всех уровнях, используя VeraCrypt для защиты данных на устройствах хранения. Symantec DLP и McAfee DLP следует использовать для мониторинга всех каналов передачи данных и предотвращения утечек через контролируемые точки доступа. Необходимо внедрить многофакторную аутентификацию (MFA) и постоянный мониторинг с использованием UEBA (User and Entity Behavior Analytics)
Амплификация трафика (VA_4)		
Предотвращение использования амплификации для усиления атак	Cloudflare 2021, Arbor Networks APS 5.0, Radware DefensePro 8.13	Инженер по безопасности должен настраивать комплексную систему защиты от DDoS, используя Cloudflare для фильтрации входящего трафика на глобальном уровне. Arbor Networks и Radware DefensePro должны быть интегрированы для анализа и предотвращения усиленных атак. Регулярные тренировки по реагированию на инциденты и симуляции атак помогут проверить готовность системы.
Отказ в обслуживании (VA_5)		
Обеспечение устойчивости системы к DoS-атакам	Cloudflare 2021, Akamai Kona Site Defender 2021, Arbor Networks APS 5.0	Инженер должен внедрить и настроить многоуровневую защиту от DoS-атак, используя Cloudflare для глобальной защиты и Akamai Kona Site Defender для оптимизации распределения трафика. Arbor Networks APS поможет в обнаружении и блокировке сложных атак. Важно настроить систему мониторинга для сбора логов и анализа аномалий в режиме реального времени, а также обеспечить постоянное обновление сигнатур угроз.

Давайте рассмотрим, для чего необходимы конкретные средства защиты в каждом векторе атак.

Разведка сети:

Nmap 7.91**:** Необходим для выявления попыток несанкционированного сканирования сети и определения открытых портов..

Wireshark 3.4.2: Используется для детального анализа сетевого трафика, что позволяет обнаружить попытки сканирования и другие подозрительные активности.

Cisco Firepower 7.0: Предназначен для защиты сети путем применения правил межсетевого экрана и мониторинга аномалий в сетевом трафике.

Обнаружение и эксплуатация уязвимостей:

Nessus 8.13: Служит для регулярного сканирования систем на наличие уязвимостей и создания подробных отчетов о безопасности.

OpenVAS 21.4.3: Применяется для обнаружения уязвимостей и постоянного мониторинга состояния безопасности сети.

Qualys 10.0: Обеспечивает управление уязвимостями, автоматическое применение патчей и контроль безопасности инфраструктуры.

Маскировка трафика:

Symantec DLP 15.7: Используется для предотвращения утечек данных и контроля доступа к конфиденциальной информации.

McAfee DLP 11.6: Предназначен для мониторинга и защиты критически важных данных от несанкционированного доступа.

VeraCrypt 1.24: Применяется для шифрования данных, обеспечивая защиту от несанкционированного доступа и утечек.

Амплификация трафика

Cloudflare 2021: Предназначен для защиты от DDoS-атак, фильтрации аномального трафика и предотвращения амплификационных атак.

Arbor Networks APS 5.0: Используется для анализа трафика и защиты от атак, использующих амплификацию.

Radware DefensePro 8.13: Служит для автоматического обнаружения и блокировки усиленных атак, обеспечивая безопасность сети

Отказ в обслуживании:

Cloudflare 2021: Применяется для распределения трафика и блокировки вредоносных запросов, защищая от DoS-атак.
Akamai Kona Site Defender 2021: Предназначен для предотвращения DoS-атак путем анализа и фильтрации сетевого трафика.
Arbor Networks APS 5.0: Используется для мониторинга и защиты от DoS-атак с использованием различных методов смягчения.

В современных условиях для эффективной защиты информации важно не только использовать технические средства и настройки, но и внедрять четкую систему разграничения доступа к ресурсам информационной системы. Это помогает минимизировать риски несанкционированного доступа и утечек данных, обеспечивая при этом необходимый уровень контроля и управления доступом к различным объектам системы.

Рекомендации Федеральной службы по техническому и экспортному контролю (ФСТЭК), а также основные положения таких стандартов, как ГОСТ Р 50922-96 «Защита информации. Основные термины и определения» и ГОСТ Р ИСО/МЭК 27001-2021 «Информационная технология. Методы и средства обеспечения безопасности. Системы менеджмента информационной безопасности. Требования», подчеркивают важность внедрения и использования разграничительных матриц доступа. Эти матрицы позволяют администраторам четко определять права доступа различных категорий пользователей к защищаемым объектам [15][16].

Одним из ключевых инструментов для управления правами доступа является разграничительная матрица доступа. Она предоставляет визуальное представление и систематизацию доступа различных ролей к объектам информационной системы. В таблице номер 24 представлены основные объекты защиты и распределение прав доступа для администратора, внутреннего пользователя и внешнего пользователя.

Таблица 25 – Пример разграничительной матрицы доступа[18][19]

Объекты защиты	Роли пользователей		
	Администратор	Внутренний пользователь	Внешний пользователь
Серверы	Полный доступ	Ограниченный доступ	Нет доступа
Базы данных	Полный доступ	Ограниченный	Нет доступа

Объекты защиты	Роли пользователей		
	Администратор	Внутренний пользователь	Внешний пользователь
		доступ	
Файловые системы	Полный доступ	Чтение и запись	Нет доступа
Сетевые устройства	Полный доступ	Нет доступа	Нет доступа
Приложения	Полный доступ	Чтение и запись	Чтение
Лог-файлы	Полный доступ	Нет доступа	Нет доступа
Системы резервного копирования	Полный доступ	Нет доступа	Нет доступа
Виртуальные машины	Полный доступ	Ограниченный доступ	Нет доступа
Электронная почта	Полный доступ	Ограниченный доступ	Чтение
Системы видеонаблюдения	Полный доступ	Ограниченный доступ	Нет доступа
Принтеры и сканеры	Полный доступ	Ограниченный доступ	Нет доступа
Устройства хранения данных	Полный доступ	Ограниченный доступ	Нет доступа

Эта глава посвящена подробному анализу различных аспектов защиты информационных систем. Мы изучили меры по противодействию атакам, требования к знаниям и навыкам администраторов, а также разработали планы действий для выбора и настройки средств защиты. Важным компонентом нашего исследования стало разграничение доступа к объектам системы, что обеспечивает четкое распределение прав различных категорий пользователей. В результате, представленная разграничительная матрица доступа позволяет эффективно контролировать и управлять доступом.

С учетом рекомендаций Федеральной службы по техническому и экспортному контролю (ФСТЭК) и в соответствии со стандартами ГОСТ Р 50922-96 и ГОСТ Р ИСО/МЭК 27001-2006, был разработан всеобъемлющий подход к обеспечению информационной безопасности. Этот подход объединяет технические меры, организационные процедуры и системное управление доступом, обеспечивая комплексную защиту информационных ресурсов.

Объединение различных методов защиты позволяет эффективно противостоять угрозам и инцидентам. Системное управление доступом, в сочетании с техническими и организационными мерами, создает надежный барьер против

несанкционированного доступа и утечек данных, минимизируя риски и обеспечивая высокий уровень безопасности.

ЗАКЛЮЧЕНИЕ

В современном мире, где информационные технологии и компьютерные системы играют ключевую роль во многих областях жизни, вопросы их защиты становятся все более важными. В этом контексте, исследование на тему “Организационно-правовая защита компьютерных, телекоммуникационных и автоматизированных систем: Проверка эхо-запроса ICMP” представляет собой значительный вклад в развитие данной области.

Новизна полученных результатов заключается в следующем:

– впервые созданы базы данных о сценариях (векторах) реализации определенной атаки и об уязвимостях для атаки типа «Проверка эхо-запроса ICMP»;

– впервые сформированы процедуры выявления и регистрации, реагирования, устранения инцидентов, основанные на агрегации знаний из баз ФСТЭК, CAPEC, NIST, MITRE ATT&CK;

– впервые сформулированы специфические инструкции для противодействия атаке на основе полученных процедур и баз данных.

Практическая ценность результатов проявляется в следующем:

– созданные базы данных о сценариях (векторах) реализации заданной атаки и об уязвимостях могут быть использованы для повышения общего уровня безопасности;

– сформированные процедуры могут быть применены при противодействии атакам типа «Проверка эхо-запроса ICMP»;

– сформулированные специфические инструкции могут быть использованы для обучения сотрудников организации, повышения их квалификации в области противодействия атакам типа «Проверка эхо-запроса ICMP».

Теоретическая значимость результатов проявляется в следующем:

– теоретическое развитие баз данных о сценариях реализации атак и об уязвимостях позволит организациям улучшить свои подходы к обеспечению безопасности и противодействию угрозам;

– включение в процедуры безопасности четко определенных процедур реагирования на атаку типа «Проверка эхо-запроса ICMP» позволяет персоналу быстро и эффективно реагировать на угрозу;

– возможно развитие специфических инструкций в направлении интеграции с другими системами и процессами безопасности.

В заключении, данная работа подчеркивает важность организационно-правовых механизмов и процедур в обеспечении безопасности компьютерных, телекоммуникационных и автоматизированных систем, а также важность разработки эффективных стратегий и мер для предотвращения кибератак, обеспечения безопасности этих критически важных систем и улучшения законодательной базы. Это важный шаг на пути к созданию более безопасного и защищенного цифрового пространства.

СПИСОК ЛИТЕРАТУРЫ

1. MITRE ATT&CK: knowledge base for adversary tactics and techniques based on real-world observations. URL: https://attack.mitre.org/ (дата обращения: 14.04.2024).
2. CAPEC - Common Attack Pattern Enumeration and Classification: community resource for identifying, understanding, and categorizing attack patterns. URL: https://capec.mitre.org/ (дата обращения: 22.05.2024).
3. National Vulnerability Database (NVD): U.S. government repository of standards based vulnerability management data represented using the Security Content Automation Protocol (SCAP). URL: https://nvd.nist.gov/ (дата обращения: 15.03.2024).
4. Common Vulnerabilities and Exposures (CVE): list of publicly disclosed information security vulnerabilities and exposures. URL: https://cve.mitre.org/ (дата обращения: 18.04.2024).
5. NIST Special Publication 800-115: Technical Guide to Information Security Testing and Assessment. URL: https://nvlpubs.nist.gov/nistpubs/Legacy/SP/nistspecialpublication800-115.pdf (дата обращения: 28.02.2024).
6. RFC 792: Internet Control Message Protocol (ICMP). URL: https://tools.ietf.org/html/rfc792 (дата обращения: 09.05.2024).
7. Symantec Internet Security Threat Report : analysis of the trends in internet security threats. URL: https://www.symantec.com/security-center/threat-report (дата обращения: 17.03.2024).
8. Kaspersky Lab: DDoS Attacks in Q2 2023. URL: https://securelist.com/ddos-attacks-in-q2-2023/ (дата обращения: 04.04.2024).
9. SANS Institute: information security resources. URL: https://www.sans.org/ (дата обращения: 19.04.2024).
10. Microsoft Security Intelligence Report: analysis on cybersecurity trends and technologies. URL: https://www.microsoft.com/security/blog/ (дата обращения: 27.03.2024).
11. Cisco 2023 Annual Cybersecurity Report: URL: https://www.cisco.com/c/en/us/products/security/annual-cybersecurity-report.html (дата обращения: 16.02.2024).

12. Gartner Research: analysis on cybersecurity trends and technologies. URL: https://www.gartner.com/en/information-technology/research/cyber-security (дата обращения: 08.04.2024).
13. Cybersecurity & Infrastructure Security Agency (CISA) : CISA Publications. URL: https://www.cisa.gov/publications-library (дата обращения: 13.02.2024).
14. ISACA: Information Systems Audit and Control Association. URL: https://www.isaca.org/ (дата обращения: 21.03.2024).
15. IEEE Xplore Digital Library: research on ICMP and network security. URL: https://ieeexplore.ieee.org/ (дата обращения: 29.04.2024).
16. Journal of Cybersecurity: Oxford Academic. URL: https://academic.oup.com/cybersecurity (дата обращения: 15.04.2024).
17. Elsevier ScienceDirect: articles on network security and cyber threats. URL: https://www.sciencedirect.com/ (дата обращения: 25.02.2024).
18. SpringerLink: research on cybersecurity and network defense mechanisms. URL: https://link.springer.com/ (дата обращения: 05.05.2024).
19. Google Scholar: academic papers on ICMP Echo Request and related attacks. URL: https://scholar.google.com/ (дата обращения: 22.03.2024).
20. National Cyber Security Centre (NCSC): UK government's cyber security advice and support. URL: https://www.ncsc.gov.uk/ (дата обращения: 03.05.2024).
21. International Organization for Standardization (ISO) : ISO/IEC 27001 Information security management. URL: https://www.iso.org/isoiec-27001-information-security.html (дата обращения: 28.04.2024).
22. Cloudflare Blog: Understanding DDoS Attacks and Mitigation Strategies. URL: https://blog.cloudflare.com/understanding-ddos/ (дата обращения: 17.02.2024).
23. The Cloudflare Blog: significant part of all DDoS attacks. URL: https://blog.cloudflare.com/ (дата обращения: 04.05.2024).
24. Habr: ландшафт DDoS-атак в России. URL: https://habr.com/ru/companies/selectel/articles/668650/ (дата обращения: 26.03.2024).
25. Компьютерра: ландшафт DDoS-атак в России во 2 квартале 2024 года кардинально изменился. URL: https://www.computerra.ru/297722/landshaft-ddos-atak-v-rossii-vo-2-kvartale-2024-goda-kardinalno-izmenilsya/ (дата обращения: 08.04.2024).

26. Лаборатория Касперского: руководство по реагированию на инциденты. URL: https://media.kasperskycontenthub.com/wp-content/uploads/sites/58/2017/08/12170645/Incident_Response_Guide_rus_2021.pdf (дата обращения: 01.05.2024).
27. Cyberpedia: энциклопедия кибербезопасности. URL: https://cyberpedia.reasonlabs.com/ (дата обращения: 11.04.2024).
28. ФСТЭК России : приказ от 11 февраля 2013 г. № 17. URL: https://fstec.ru/dokumenty/vse-dokumenty/prikazy/prikaz-fstek-rossii-ot-11-fevralya-2013-g-n-17 (дата обращения: 16.02.2024).
29. CWE: общие уязвимости и экспозиции. URL: https://cwe.mitre.org/data/index.html (дата обращения: 28.03.2024).
30. NIST Special Publication 800-61r2: руководство по реагированию на компьютерные инциденты. URL: https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-61r2.pdf (дата обращения: 10.04.2024).
31. NIST Special Publication 800-92: руководство по журналированию безопасности компьютеров. URL: https://nvlpubs.nist.gov/nistpubs/Legacy/SP/nistspecialpublication800-92.pdf (дата обращения: 22.05.2024).
32. Лаборатория Касперского: инциденты информационной безопасности. URL:(https://media.kasperskycontenthub.com/wpcontent/uploads/sites/58/2017/08/12170645/Incident_Response_Guide_rus_2021.pdf).
33. Код Безопасности: лучшие практики и рекомендации по реагированию на инциденты. URL: (https://media.kasperskycontenthub.com/wp-content/uploads/sites/43/2018/03/07172131/Incident_Response_Guide_rus.pdf).
34. ГОСТ Р 59712-2022: управление компьютерными инцидентами. Руководство по реагированию на компьютерные инциденты.
35. ГОСТ Р ИСО/МЭК ТО 18044-2007: менеджмент инцидентов информационной безопасности.
36. ГОСТ Р 57580.1-2017: защита информации. Основные меры защиты информации.

37. Приказ ФСТЭК России от 11 февраля 2013 г. № 17: требования к обеспечению защиты персональных данных. URL: (недоступно в сети).
38. ГОСТ Р 50922-96: защита информации. Основные термины и определения. URL: (недоступно в сети).
39. ГОСТ Р ИСО/МЭК 27001-2021: методы и средства обеспечения безопасности. URL: (недоступно в сети).
40. NIST Special Publication 800-53: рекомендации по безопасности и конфиденциальности. URL: (недоступно в сети).

Приложение А

Этапность реализации кибератак, рекомендованная MITRE ATT&CK		В соответствие с MITRE – этапностью регистрируемые инциденты пары атака - уязвимость	Меры реагирования на регистрируемые инциденты, порожденные парой атака-уязвимость	Меры ликвидации последствий инцидентов, порожденных парой атака-уязвимость
1	Разведка	**Инциденты, связанные с обнаружением необычного трафика при уязвимости CWE-200:** необычный трафик указывает на разведку сети с целью получения информации о системе и возможностях для последующей атаки	- Разработка и внедрение процедур инцидентного реагирования и плана восстановления, чтобы обеспечить быстрое и координированное устранение последствий инцидентов. Программы: Splunk, IBM QRadar. - **Внедрение систем IDS/IPS:** Настройка систем обнаружения и предотвращения вторжений (IDS/IPS) для автоматического мониторинга и блокировки подозрительного трафика, что минимизирует риск успешных атак. Программы: Suricata, Snort. - **Настройка оповещений и уведомлений:** Внедрение системы оповещений, которая уведомляет соответствующий персонал о подозрительной активности в реальном времени, чтобы обеспечить оперативное реагирование. Программы: Splunk, ELK Stack.	- **Комплексный анализ безопасности:** Регулярное проведение проверок безопасности для выявления и устранения уязвимостей, используемых для разведки. Это включает в себя обновление всех систем и политик безопасности. Программы: Wireshark, Snort. - **Пересмотр и обновление политик безопасности:** Регулярный пересмотр и обновление политик безопасности, чтобы предотвратить несанкционированный доступ. Это включает в себя улучшение мер аутентификации и управления доступом. Программы: Cisco ISE, Microsoft Azure AD. - **Восстановление и обновление систем безопасности:** После инцидента провести восстановление и обновление систем безопасности для устранения уязвимостей и предотвращения повторных атак. Программы: Splunk, IBM QRadar.

		Инциденты, связанные с обнаружением необычного трафика при уязвимости CWE-542: необычный трафик указывает на разведку сети с целью получения информации о системе и возможностях для последующей атаки	- **Внедрение протоколов шифрования:** Использование протоколов шифрования, таких как TLS, для защиты передаваемых данных, что предотвращает их перехват и анализ злоумышленниками. Программы: OpenSSL, Let's Encrypt. - **Настройка межсетевых экранов:** Регулярное обновление и настройка межсетевых экранов для блокировки несанкционированных запросов и защиты сети от неавторизованного доступа. Программы: pfSense, Cisco ASA. - **Обучение сотрудников:** Проведение регулярного обучения для сотрудников, чтобы повысить их осведомленность о методах защиты информации и правильном реагировании на инциденты. Программы: SANS Security Awareness, KnowBe4.	- **Анализ и устранение уязвимостей:** Регулярное проведение анализа уязвимостей для выявления и устранения слабых мест, которые могут быть использованы для разведки сети. Программы: Nessus, OpenVAS. - **Восстановление и укрепление мер управления доступом:** Пересмотр и усиление мер управления доступом для предотвращения несанкционированного доступа. Это включает внедрение многофакторной аутентификации (MFA). Программы: Netwrix Auditor, SolarWinds NCM. - **Разработка и внедрение политики инцидентного реагирования:** Создание и внедрение подробных процедур и плана реагирования на инциденты для быстрого и координированного устранения последствий атак. Программы: Splunk, IBM QRadar.
		Инциденты, связанные с определением уязвимых систем при уязвимости CWE-200: необычный трафик указывает на попытки определить уязвимые системы с использованием запросов с недопустимыми значениями параметров или обходом механизмов аутентификации	- **Углубленный анализ сетевого трафика:** Использование инструментов анализа трафика, таких как Wireshark или Zeek, для выявления подозрительных действий, указывающих на попытки определения уязвимостей. - **Настройка строгих политик контроля доступа:** Ограничение доступа к системам и	- **Комплексный аудит безопасности:** Регулярное проведение аудита безопасности для выявления и устранения уязвимостей, связанных с утечкой чувствительной информации. Программы: Nessus, OpenVAS. - **Усиление систем мониторинга:** Обновление и настройка систем мониторинга для улучшения обнаружения и анализа необычного трафика. Программы: SolarWinds, Nagios.

			данным на основе принципа минимальных привилегий, чтобы минимизировать риск несанкционированного доступа. - **Проведение учений по кибербезопасности:** Регулярное проведение учений по реагированию на инциденты для подготовки сотрудников к действиям в случае выявления подозрительного трафика.	- **Меры по восстановлению данных:** Восстановление и защита данных, которые могли быть скомпрометированы в результате попыток определения уязвимых систем. Программы: Veeam, Acronis.
		Инциденты, связанные с определением уязвимых систем при уязвимости CWE-20: необычный трафик указывает на попытки определить уязвимые системы с использованием запросов с недопустимыми значениями параметров или обходом механизмов аутентификации	- **Регулярное тестирование и валидация входных данных:** Внедрение и регулярное тестирование фильтров для проверки корректности входных данных, что предотвращает атаки с использованием недопустимых значений. Программы: Burp Suite. - **Проведение кодового анализа:** Регулярный анализ исходного кода на предмет наличия уязвимостей, связанных с недопустимыми значениями параметров. Программы: SonarQube, Checkmarx. - **Обучение разработчиков:** Проведение регулярного обучения разработчиков по безопасному программированию и	- **Обновление и исправление уязвимых компонентов:** Устранение уязвимостей в коде и конфигурации систем для предотвращения их эксплуатации. Программы: Fortify, Veracode. - **Укрепление инфраструктуры аутентификации:** Внедрение многофакторной аутентификации (MFA) и улучшение мер безопасности аутентификации. Программы: Duo Security, Google Authenticator. - **Анализ и аудит конфигурации:** Проведение регулярного анализа и аудита конфигурации систем для предотвращения уязвимостей. Программы: AuditBoard, Netwrix.

			методам защиты от атак, связанных с вводом данных.	
		Инциденты, связанные с определением уязвимых систем при уязвимости CWE-287: необычный трафик указывает на попытки определить уязвимые системы с использованием запросов с недопустимыми значениями параметров или обходом механизмов аутентификации	- **Проверка и усиление мер аутентификации:** Внедрение и регулярное тестирование систем многофакторной аутентификации для предотвращения обхода механизмов аутентификации. Программы: Authy, Okta. - **Мониторинг и анализ попыток входа:** Регулярный мониторинг и анализ попыток входа для выявления подозрительных действий и предотвращения несанкционированного доступа. Программы: Splunk, ELK Stack. - **Проведение тестов на проникновение:** Регулярное проведение тестов на проникновение для проверки надежности механизмов аутентификации. Программы: Metasploit, Burp Suite.	- **Обновление и корректировка политик безопасности:** Пересмотр и обновление политик безопасности для устранения выявленных уязвимостей в аутентификации. Программы: Microsoft Azure AD, Cisco ISE. - **Укрепление систем контроля доступа:** Обновление и улучшение систем контроля доступа для предотвращения обхода механизмов аутентификации. Программы: Centrify, BeyondTrust. - **Анализ журналов безопасности:** Регулярный анализ журналов безопасности для выявления и устранения уязвимостей в системах аутентификации. Программы: LogRhythm, Splunk.
		Инциденты, связанные с определением уязвимых систем при уязвимости CWE-306: необычный трафик указывает на попытки определить уязвимые системы с использованием запросов с	- **Регулярное тестирование механизмов аутентификации:** Внедрение регулярного тестирования и проверки надежности механизмов аутентификации для предотвращения их обхода. Программы:	- **Обновление систем безопасности:** Проведение регулярных обновлений и исправлений систем безопасности для устранения уязвимостей. Программы: Qualys, Rapid7. - **Усиление мер безопасности при доступе:** Пересмотр и усиление мер безопасности при доступе для предотвращения обхода

		недопустимыми значениями параметров или обходом механизмов аутентификации	Ping Identity, RSA SecurID. - **Настройка и обновление межсетевых экранов:** Регулярное обновление и настройка межсетевых экранов для блокировки подозрительных запросов. Программы: Palo Alto Networks, Fortinet. - **Обучение и повышение осведомленности сотрудников:** Регулярное проведение обучения сотрудников по методам безопасного доступа и защите аутентификационных данных. Программы: KnowBe4, SANS Security Awareness.	механизмов аутентификации. Программы: RSA Archer, CyberArk. - **Внедрение системы контроля и мониторинга доступа:** Обновление систем контроля и мониторинга доступа для предотвращения обхода механизмов аутентификации. Программы: Splunk, SolarWinds.
2	Подготовка ресурсов	-	-	-
3	Первоначальный доступ	-	-	-
4	Выполнение	-	-	-
5	Закрепление	-	-	-
6	Повышение привилегий	-	-	-
7	Предотвращение обнаружения	-	-	-
8	Получение учетных данных	-	-	-
9	Изучение	-	-	-
10	Перемещение внутри периметра	-	-	-
11	Сбор данных	-	-	-
12	Организация управления	-	-	-

13	Эксфильтрация данных	**Инциденты, связанные с эксфильтрацией данных при уязвимости CWE-200:** необычный трафик указывает на попытки эксфильтрации данных через уязвимые компоненты системы	- **Мониторинг и анализ трафика:** Использование продвинутых систем мониторинга для анализа сетевого трафика и выявления попыток эксфильтрации данных. Программы: Zeek, Argus. - **Внедрение систем DLP:** Использование систем предотвращения утечек данных (DLP) для мониторинга и защиты данных от несанкционированного доступа и передачи. Программы: Symantec DLP, McAfee Total Protection for Data Loss Prevention. - **Укрепление мер контроля доступа:** Внедрение строгих политик контроля доступа и шифрования данных для предотвращения несанкционированного доступа. Программы: Vera, CipherCloud.	- **Обновление и патчинг систем:** Регулярное обновление и патчинг систем для устранения уязвимостей, связанных с утечкой данных. Программы: Patch My PC, Microsoft WSUS. - **Аудит конфигурации и политики безопасности:** Регулярное проведение аудита конфигурации и политик безопасности для выявления и устранения уязвимостей. Программы: Tripwire, Qualys. - **Обучение сотрудников:** Регулярное обучение сотрудников методам предотвращения утечек данных и правильному использованию систем безопасности. Программы: KnowBe4, Infosec IQ.
		Инциденты, связанные с эксфильтрацией данных при уязвимости CWE-601: необычный трафик указывает на попытки эксфильтрации данных через уязвимые компоненты системы, такие как незащищенные ссылки	- **Обнаружение и блокировка уязвимых ссылок:** Использование инструментов для сканирования и выявления незащищенных ссылок в системе, а также блокировка их использования. Программы: Netsparker, Burp Suite. - **Обнаружение и блокировка уязвимых ссылок:** Использование инструментов для сканирования и выявления незащищенных ссылок в системе, а также блокировка их использования. Программы:	- **Проверка и обновление ссылок:** Обновление и исправление уязвимых ссылок на веб-сайтах и в системах для предотвращения их эксплуатации. Программы: SiteLock, Wordfence. - **Аудит веб-приложений:** Проведение регулярных аудитов веб-приложений для выявления и устранения уязвимостей, связанных с незащищенными ссылками. Программы: Acunetix, Qualys Web Application Scanning. - **Восстановление данных и систем:** Проведение восстановления данных и систем после инцидента, чтобы минимизировать ущерб от утечек данных. Программы: Veeam, Acronis.

			Netsparker, Burp Suite. - **Шифрование и защита данных:** Внедрение шифрования и других мер защиты данных при передаче, чтобы предотвратить их перехват и использование злоумышленниками. Программы: SSL/TLS, Let's Encrypt.	
		Инциденты, связанные с эксфильтрацией данных при уязвимости CWE-918: необычный трафик, указывает на попытки эксфильтрации данных через уязвимые API	- **Анализ и мониторинг API:** Использование инструментов для мониторинга и анализа трафика API, чтобы выявлять подозрительные запросы и попытки эксфильтрации данных. Программы: API Fortress, Postman. - **Внедрение средств аутентификации и авторизации:** Использование современных средств аутентификации и авторизации для защиты API от несанкционированного доступа. Программы: OAuth, OpenID Connect. - **Контроль доступа и шифрование:** Ограничение доступа к API только авторизованным пользователям и шифрование передаваемых данных. Программы: JWT, TLS.	- **Обновление и защита API:** Регулярное обновление и защита API от уязвимостей, чтобы предотвратить их эксплуатацию злоумышленниками. Программы: Apigee, AWS API Gateway. - **Аудит и тестирование API:** Проведение регулярных аудитов и тестирования API для выявления и устранения уязвимостей. Программы: Postman, Insomnia. - **Обучение разработчиков:** Регулярное обучение разработчиков по безопасному программированию и защите API. Программы: SANS Secure Coding, OWASP API Security.

14	Деструктивное воздействие	**Инциденты, связанные с амплификацией трафика (CWE-400):** необычный трафик указывает на попытки амплификации трафика через уязвимые системы для усиления атак на целевые ресурсы	- Настройка и регулярное обновление систем защиты от DDoS-атак, что позволяет обнаруживать и блокировать попытки амплификации трафика и минимизировать воздействие атак. Программы: Cloudflare, Arbor Networks. - Увеличение пропускной способности сети и использование облачных решений для распределения нагрузки, что помогает справляться с внезапными пиками трафика и снижает риск перегрузки.	- Анализ и устранение уязвимостей, которые могут быть использованы для амплификации трафика, включая обновление всех систем и усиление мер безопасности. Программы: Akamai Kona Site Defender, F5 Silverline DDoS Protection. - Восстановление нормальной работы сети и сервисов после атаки путем оперативного реагирования и устранения последствий, а также анализа инцидента для предотвращения повторений. Программы: Cisco Umbrella, Fortinet FortiDDoS.
		Инциденты, связанные с отказом в обслуживании при уязвимости CWE-20: необычный трафик указывает на попытки отказа в обслуживании путем отправки большого количества недопустимых запросов	- **Фильтрация и проверка входных данных:** Внедрение строгих фильтров и проверок входных данных на уровне веб-приложений и серверов для предотвращения отправки недопустимых запросов. Программы: OWASP ZAP, Burp Suite. - **Настройка WAF:** Внедрение и настройка веб-аппликационных фаерволов (WAF) для защиты веб-приложений от атак с использованием недопустимых запросов. Программы: ModSecurity, Imperva Incapsula. - **Проведение тестов на проникновение:** Регулярное проведение тестов на проникновение для выявления возможных уязвимостей в приложениях.	- **Патчинг и обновление систем:** Регулярное обновление систем и установка патчей для устранения уязвимостей, связанных с вводом недопустимых данных. - **Аудит безопасности приложений:** Проведение регулярного аудита безопасности веб-приложений для выявления и устранения уязвимостей. - **Обучение разработчиков:** Регулярное обучение разработчиков методам безопасного программирования и предотвращения уязвимостей.

			Программы: Metasploit, Kali Linux.	
		Инциденты, связанные с отказом в обслуживании при уязвимости CWE-119: необычный трафик указывает на попытки отказа в обслуживании путем использования уязвимостей в обработке данных	**Мониторинг и анализ трафика:** Использование продвинутых систем мониторинга для анализа сетевого трафика и выявления подозрительной активности. Программы: SolarWinds, Nagios. - **Внедрение систем IDS/IPS:** Использование систем обнаружения и предотвращения вторжений для автоматического мониторинга и блокировки подозрительного трафика. Программы: Snort, Suricata. - **Настройка оповещений:** Внедрение систем оповещений, которые уведомляют соответствующий персонал о подозрительной активности в реальном времени. Программы: Splunk, ELK Stack.	- **Обновление и исправление уязвимостей:** Регулярное обновление и исправление уязвимостей в обработке данных для предотвращения их эксплуатации. - **Аудит и анализ исходного кода:** Проведение регулярных аудитов и анализа исходного кода для выявления уязвимостей. **Проведение стресс-тестов:** Регулярное проведение стресс-тестов для проверки устойчивости систем к DoS-атакам.
		Инциденты, связанные с отказом в обслуживании при уязвимости CWE-400: необычный трафик указывает на попытки отказа в обслуживании путем отправки большого количества недопустимых запросов	- **Увеличение пропускной способности сети:** Увеличение пропускной способности сети для снижения воздействия DoS-атак. Программы: Cloudflare, Akamai. - **Внедрение и настройка систем защиты от DoS-атак:** Использование специализированных систем для защиты от DoS-атак. - **Настройка и обновление межсетевых экранов:** Обновление межсетевых экранов для блокировки подозрительного	- **Анализ и обновление мер защиты:** Проведение регулярного анализа и обновления мер защиты для предотвращения DoS-атак. - **Аудит конфигурации сетевого оборудования:** Регулярный аудит конфигурации сетевого оборудования для выявления и устранения уязвимостей. - **Обучение сотрудников:** Регулярное обучение сотрудников методам защиты от DoS-атак и реагирования на инциденты.

			трафика и предотвращения DoS-атак.	
		Инциденты, связанные с отказом в обслуживании при уязвимости CWE-404: необычный трафик указывает на попытки отказа в обслуживании путем использования уязвимостей в обработке данных	- **Мониторинг и управление журналами:** Использование систем управления журналами для мониторинга и анализа логов с целью выявления подозрительной активности. - **Проведение анализов на отказоустойчивость:** Регулярное проведение анализов на отказоустойчивость систем и приложений для выявления и устранения слабых мест. - **Настройка систем резервирования:** Внедрение систем резервирования и восстановления для минимизации воздействия DoS-атак.	- **Проверка и обновление конфигураций:** Регулярная проверка и обновление конфигураций систем для устранения уязвимостей. - **Усиление мер безопасности приложений:** Внедрение и обновление мер безопасности для защиты приложений от DoS-атак. - **Проведение тестов на проникновение:** Регулярное проведение тестов на проникновение для проверки надежности систем против DoS-атак.

Приложение Б

Таблица Б1 - Пример плана действий Архитектор КБ при выборе и настройке СЗИ

Требование к защите информации от атаки компьютерными вирусами	Средство защиты информации, обеспечивающие выполнение данных требований	Рекомендация по настройке параметров средств защиты информации
Сканирование сети (VA_1)		
Предотвращение несанкционированного сканирования сети и открытых портов	Nmap 7.91, Wireshark 3.4.2, Cisco Firepower 7.0	Архитектор КБ должен определить структуру сети и применить сегментацию для минимизации последствий сканирования. Настроить Nmap для периодического внутреннего аудита и использовать Wireshark для анализа трафика в критических сегментах. Cisco Firepower следует настроить для интеграции с центральным мониторингом сети и автоматической блокировки подозрительных активностей.
Обнаружение и эксплуатация уязвимостей (VA_2)		
Обнаружение и устранение уязвимостей, регулярное обновление ПО	Обнаружение и устранение уязвимостей, регулярное обновление ПО	Архитектор КБ должен внедрить систему управления уязвимостями, включая Nessus для регулярного сканирования и OpenVAS для мониторинга в реальном времени. Использовать Qualys для автоматизации обновлений и патчей. Создать протоколы реагирования на выявленные уязвимости и интегрировать их с системами управления инцидентами.
Маскировка трафика (VA_3)		
Защита данных от несанкционированного доступа и утечек	Symantec DLP 15.7, McAfee DLP 11.6, VeraCrypt 1.24	Архитектор КБ должен обеспечить шифрование всех критичных данных с помощью VeraCrypt и настроить DLP системы, такие как Symantec и McAfee, для мониторинга и предотвращения утечек данных. Внедрить многоуровневую аутентификацию и контроль доступа, а также использовать поведенческий анализ для выявления аномалий.
Амплификация трафика (VA_4)		
Предотвращение использования амплификации для усиления атак	Cloudflare 2021, Arbor Networks APS 5.0, Radware DefensePro 8.13	Архитектор КБ должен настроить многоуровневую защиту от DDoS, используя Cloudflare для фильтрации трафика и Arbor Networks для анализа и предотвращения усиленных атак. Radware DefensePro следует использовать для постоянного мониторинга и анализа трафика. Регулярно проводить тестирования на отказоустойчивость и симуляции DDoS атак.
Отказ в обслуживании (VA_5)		
Обеспечение устойчивости системы к DoS-атакам	Cloudflare 2021, Akamai Kona Site Defender 2021, Arbor Networks APS 5.0	Архитектор КБ должен внедрить комплексную систему защиты от DoS-атак, используя Cloudflare для глобальной защиты и Akamai Kona Site Defender для

		оптимизации распределения трафика. Arbor Networks APS следует настроить для детального мониторинга и предотвращения сложных атак. Включить автоматическое создание отчетов и аналитики для постоянного улучшения защиты.

Таблица Б2 - Пример плана действий Аналитика КБ при выборе и настройке СЗИ

Требование к защите информации от атаки компьютерными вирусами	Средство защиты информации, обеспечивающие выполнение данных требований	Рекомендация по настройке параметров средств защиты информации
Сканирование сети (VA_1)		
Предотвращение несанкционированного сканирования сети и открытых портов	Nmap 7.91, Wireshark 3.4.2, Cisco Firepower 7.0	Аналитику КБ следует использовать Nmap для детального картографирования сети и выявления всех активных устройств. Wireshark поможет в глубоком анализе пакетов, чтобы выявить подозрительную активность. Cisco Firepower необходимо настроить для автоматической блокировки известных угроз и интеграции с SIEM для детального мониторинга.
Обнаружение и эксплуатация уязвимостей (VA_2)		
Обнаружение и устранение уязвимостей, регулярное обновление ПО	Nessus 8.13, OpenVAS 21.4.3, Qualys 10.0	Аналитик КБ должен проводить анализ уязвимостей с использованием Nessus и OpenVAS для получения данных о текущем состоянии безопасности. Использовать Qualys для автоматизации выявления и устранения уязвимостей. Результаты анализа интегрировать с системами управления инцидентами для дальнейшего анализа и отчетности.
Маскировка трафика (VA_3)		
Защита данных от несанкционированного доступа и утечек	Symantec DLP 15.7, McAfee DLP 11.6, VeraCrypt 1.24	Аналитик КБ должен анализировать потоки данных с помощью Symantec DLP и McAfee DLP для выявления попыток несанкционированного доступа. Настроить VeraCrypt для шифрования критичных данных и использования данных аналитики для мониторинга поведения пользователей. Включить механизмы аномалий поведения (UEBA) для улучшения мониторинга.
Амплификация трафика (VA_4)		
Предотвращение использования амплификации для усиления атак	Cloudflare 2021, Arbor Networks APS 5.0, Radware DefensePro 8.13	Аналитику КБ необходимо использовать данные от Cloudflare и Arbor Networks для анализа и предотвращения амплификационных атак. Radware DefensePro поможет в анализе аномального трафика в режиме реального времени. Включить регулярные симуляции атак для проверки и улучшения стратегии защиты
Отказ в обслуживании (VA_5)		
Обеспечение устойчивости системы к	Cloudflare 2021, Akamai Kona Site Defender 2021,	Аналитик КБ должен использовать данные от Cloudflare и Akamai для анализа и

DoS-атакам	Arbor Networks APS 5.0	распределения трафика, предотвращая DoS-атаки. Arbor Networks APS поможет в детальном анализе и предотвращении сложных DoS-атак. Настроить систему мониторинга для сбора данных и анализа аномалий в режиме реального времени

Таблица Б3 - Пример плана действий Тестировщика проникновения при выборе и настройке СЗИ

Требование к защите информации от атаки компьютерными вирусами	Средство защиты информации, обеспечивающие выполнение данных требований	Рекомендация по настройке параметров средств защиты информации
Сканирование сети (VA_1)		
Предотвращение несанкционированного сканирования сети и открытых портов	Nmap 7.91, Wireshark 3.4.2, Metasploit	Тестировщик проникновения должен использовать Nmap для выявления открытых портов и потенциальных точек входа. Wireshark помогает в анализе трафика для обнаружения подозрительной активности. Metasploit используется для тестирования уязвимостей и проверки их эксплуатационной пригодности.
Обнаружение и эксплуатация уязвимостей (VA_2)		
Обнаружение и устранение уязвимостей, регулярное обновление ПО	Nessus 8.13, OpenVAS 21.4.3, Burp Suite	Тестировщик проникновения должен использовать Nessus и OpenVAS для поиска уязвимостей в системах. Burp Suite помогает в анализе и эксплуатации веб-уязвимостей. Регулярно обновлять базы данных уязвимостей и проводить тесты на проникновение для проверки эффективности патчей.
Маскировка трафика (VA_3)		
Защита данных от несанкционированного доступа и утечек	Symantec DLP 15.7, McAfee DLP 11.6, VeraCrypt 1.24	Тестировщик проникновения должен использовать Symantec DLP и McAfee DLP для мониторинга попыток утечки данных. VeraCrypt применяется для шифрования данных. Проведение тестов на проникновение для выявления возможных путей утечки данных и обеспечения их защиты.
Амплификация трафика (VA_4)		
Предотвращение использования амплификации для усиления атак	Cloudflare 2021, Arbor Networks APS 5.0, Radware DefensePro 8.13	Тестировщик проникновения должен использовать Cloudflare для защиты от DDoS-атак и фильтрации аномального трафика. Arbor Networks и Radware DefensePro помогают в анализе и предотвращении усиленных атак. Регулярные тесты на проникновение для проверки эффективности защиты от DDoS-атак.
Отказ в обслуживании (VA_5)		
Обеспечение устойчивости системы к	Cloudflare 2021, Akamai Kona Site Defender 2021,	Тестировщик проникновения должен использовать Cloudflare и Akamai Kona Site

DoS-атакам	Arbor Networks APS 5.0	Defender для распределения и защиты трафика. Arbor Networks APS используется для детального анализа и предотвращения сложных DoS-атак. Регулярные тесты на проникновение и анализ логов для улучшения стратегии защиты.

Таблица Б4 - Пример плана действий Консультанта по безопасности при выборе и настройке СЗИ.

Требование к защите информации от атаки компьютерными вирусами	Средство защиты информации, обеспечивающие выполнение данных требований	Рекомендация по настройке параметров средств защиты информации
Сканирование сети (VA_1)		
Предотвращение несанкционированного сканирования сети и открытых портов	Nmap 7.91, Wireshark 3.4.2, Cisco Firepower 7.0	Консультанту по безопасности следует использовать Nmap для выявления открытых портов и оценки безопасности сети. Настроить Wireshark для детального анализа трафика и выявления аномалий. Конфигурировать Cisco Firepower для активного мониторинга и блокировки подозрительных действий.
Обнаружение и эксплуатация уязвимостей (VA_2)		
Обнаружение и устранение уязвимостей, регулярное обновление ПО	Nessus 8.13, OpenVAS 21.4.3, Qualys 10.0	Консультант по безопасности должен применять Nessus для систематического сканирования уязвимостей и OpenVAS для постоянного мониторинга. Использовать Qualys для автоматизации обновления патчей. Разрабатывать рекомендации по устранению уязвимостей на основе данных анализа и консультировать по их внедрению.
Маскировка трафика (VA_3)		
Защита данных от несанкционированного доступа и утечек	Symantec DLP 15.7, McAfee DLP 11.6, VeraCrypt 1.24	Консультанту по безопасности рекомендуется использовать Symantec DLP и McAfee DLP для мониторинга и предотвращения утечек данных. Настроить VeraCrypt для шифрования критически важных данных. Внедрить поведенческий анализ для выявления подозрительных действий пользователей и аномалий в передаче данных.
Амплификация трафика (VA_4)		
Предотвращение использования амплификации для усиления атак	Cloudflare 2021, Arbor Networks APS 5.0, Radware DefensePro 8.13	Консультанту по безопасности следует настроить Cloudflare для защиты от DDoS-атак и Arbor Networks для анализа аномального трафика. Radware DefensePro поможет в предотвращении усиленных атак. Важно проводить регулярные тестирования системы для оценки ее устойчивости к атакам и разработке рекомендаций по улучшению.
Отказ в обслуживании (VA_5)		

Обеспечение устойчивости системы к DoS-атакам	Cloudflare 2021, Akamai Kona Site Defender 2021, Arbor Networks APS 5.0	Консультанту по безопасности рекомендуется использовать Cloudflare и Akamai для оптимизации распределения трафика и предотвращения DoS-атак. Arbor Networks APS следует применять для анализа и блокировки сложных DoS-атак. Настроить систему мониторинга для постоянного анализа логов и создания рекомендаций по улучшению защиты.

Таблица Б5 - Пример плана действий Менеджера по ИБ при выборе и настройке СЗИ.

Требование к защите информации от атаки компьютерными вирусами	Средство защиты информации, обеспечивающие выполнение данных требований	Рекомендация по настройке параметров средств защиты информации
Сканирование сети (VA_1)		
Предотвращение несанкционированного сканирования сети и открытых портов	Nmap 7.91, Wireshark 3.4.2, Cisco Firepower 7.0	Менеджеру по ИБ следует внедрить процесс регулярного сканирования сети с использованием Nmap для выявления открытых портов и уязвимостей. Настроить Wireshark для мониторинга и анализа сетевого трафика. Cisco Firepower использовать для автоматической блокировки подозрительных IP-адресов и интеграции с SIEM для централизованного мониторинга.
Обнаружение и эксплуатация уязвимостей (VA_2)		
Обнаружение и устранение уязвимостей, регулярное обновление ПО	Nessus 8.13, OpenVAS 21.4.3, Qualys 10.0	Менеджеру по ИБ необходимо организовать процесс регулярного сканирования на уязвимости с использованием Nessus и OpenVAS. Использовать Qualys для автоматизации обновлений патчей и управления уязвимостями. Настроить процессы для формирования отчетов и рекомендаций по устранению уязвимостей, а также для их внедрения.
Маскировка трафика (VA_3)		
Защита данных от несанкционированного доступа и утечек	Symantec DLP 15.7, McAfee DLP 11.6, VeraCrypt 1.24	Менеджеру по ИБ следует настроить DLP системы, такие как Symantec и McAfee, для мониторинга и предотвращения утечек данных. Внедрить использование VeraCrypt для шифрования критически важных данных. Настроить поведенческий анализ для выявления подозрительных действий и аномалий.
Амплификация трафика (VA_4)		
Предотвращение использования амплификации для усиления атак	Cloudflare 2021, Arbor Networks APS 5.0, Radware DefensePro 8.13	Менеджеру по ИБ необходимо интегрировать системы Cloudflare и Arbor Networks для защиты от DDoS-атак и анализа аномального трафика. Radware DefensePro следует использовать для предотвращения усиленных атак. Проводить регулярные тесты на

		устойчивость системы к атакам и разработать рекомендации по улучшению защиты.
Отказ в обслуживании (VA_5)		
Обеспечение устойчивости системы к DoS-атакам	Cloudflare 2021, Akamai Kona Site Defender 2021, Arbor Networks APS 5.0	Менеджеру по ИБ следует внедрить многоуровневую защиту от DoS-атак с использованием Cloudflare и Akamai для оптимизации распределения трафика. Arbor Networks APS необходимо для детального анализа и предотвращения сложных DoS-атак. Настроить системы для автоматического мониторинга и создания отчетов, а также анализа логов для улучшения стратегии защиты.

Таблица Б6 - Пример плана действий Разработчика ПО по КБ при выборе и настройке СЗИ.

Требование к защите информации от атаки компьютерными вирусами	Средство защиты информации, обеспечивающие выполнение данных требований	Рекомендация по настройке параметров средств защиты информации
Сканирование сети (VA_1)		
Предотвращение несанкционированного сканирования сети и открытых портов	Nmap 7.91, Wireshark 3.4.2, Cisco Firepower 7.0	Разработчику ПО по КБ следует интегрировать Nmap для выявления уязвимостей в сети и использования результатов для разработки более безопасных приложений. Настроить Wireshark для анализа сетевого трафика и идентификации потенциальных угроз. Cisco Firepower использовать для защиты сетевой инфраструктуры и интеграции с системой разработки для быстрого реагирования на угрозы.
Обнаружение и эксплуатация уязвимостей (VA_2)		
Обнаружение и устранение уязвимостей, регулярное обновление ПО	Nessus 8.13, OpenVAS 21.4.3, Qualys 10.0	Разработчику ПО по КБ необходимо использовать Nessus и OpenVAS для регулярного сканирования на уязвимости в коде и инфраструктуре. Qualys поможет в автоматизации обновлений и патчей для минимизации уязвимостей. Настроить процессы для анализа отчетов и внедрения исправлений в цикле разработки.
Маскировка трафика (VA_3)		
Защита данных от несанкционированного доступа и утечек	Symantec DLP 15.7, McAfee DLP 11.6, VeraCrypt 1.24	Разработчику ПО по КБ следует интегрировать Symantec DLP и McAfee DLP для мониторинга и предотвращения утечек данных в разработанных приложениях. Использовать VeraCrypt для шифрования данных. Внедрить процедуры для регулярного аудита безопасности данных и анализа поведения пользователей в приложениях.
Амплификация трафика (VA_4)		

Предотвращение использования амплификации для усиления атак	Cloudflare 2021, Arbor Networks APS 5.0, Radware DefensePro 8.13	Разработчику ПО по КБ нужно использовать Cloudflare и Arbor Networks для защиты от DDoS-атак и анализа аномального трафика. Radware DefensePro поможет в предотвращении усиленных атак. Регулярно тестировать приложения на устойчивость к DDoS-атакам и разрабатывать улучшения на основе результатов тестов.
Отказ в обслуживании (VA_5)		
Обеспечение устойчивости системы к DoS-атакам	Cloudflare 2021, Akamai Kona Site Defender 2021, Arbor Networks APS 5.0	Разработчику ПО по КБ рекомендуется интегрировать Cloudflare и Akamai Kona Site Defender для оптимизации защиты от DoS-атак в разработанных приложениях. Arbor Networks APS следует использовать для анализа и предотвращения сложных DoS-атак. Настроить системы для автоматического мониторинга и анализа логов для улучшения стратегии защиты приложений.

Таблица Б7 - Пример плана действий Специалиста по реагированию на инциденты при выборе и настройке СЗИ.

Требование к защите информации от атаки компьютерными вирусами	Средство защиты информации, обеспечивающие выполнение данных требований	Рекомендация по настройке параметров средств защиты информации
Сканирование сети (VA_1)		
Предотвращение несанкционированного сканирования сети и открытых портов	Nmap 7.91, Wireshark 3.4.2, Cisco Firepower 7.0	Специалисту по реагированию на инциденты следует использовать Nmap для регулярного сканирования сети и выявления подозрительной активности. Wireshark помогает в анализе трафика и выявлении несанкционированного доступа. Cisco Firepower используется для мгновенного реагирования на инциденты и блокировки подозрительных IP-адресов.
Обнаружение и эксплуатация уязвимостей (VA_2)		
Обнаружение и устранение уязвимостей, регулярное обновление ПО	Nessus 8.13, OpenVAS 21.4.3, Qualys 10.0	Специалисту по реагированию на инциденты необходимо использовать Nessus и OpenVAS для постоянного мониторинга уязвимостей. Qualys помогает в автоматизации процесса обновления патчей и управлении уязвимостями. Настроить системы для оперативного оповещения о выявленных уязвимостях и быстрой реализации корректирующих мер.
Маскировка трафика (VA_3)		
Защита данных от несанкционированного доступа и утечек	Symantec DLP 15.7, McAfee DLP 11.6, VeraCrypt 1.24	Специалисту по реагированию на инциденты следует использовать Symantec DLP и McAfee DLP для мониторинга попыток утечки данных и быстрой реакции на инциденты. VeraCrypt используется для шифрования данных. Внедрить процедуры

		для анализа и реагирования на аномалии в поведении пользователей и утечках данных.
Амплификация трафика (VA_4)		
Предотвращение использования амплификации для усиления атак	Cloudflare 2021, Arbor Networks APS 5.0, Radware DefensePro 8.13	Специалисту по реагированию на инциденты нужно использовать Cloudflare и Arbor Networks для защиты от DDoS-атак и анализа аномального трафика. Radware DefensePro помогает в предотвращении усиленных атак. Регулярно тестировать системы на устойчивость к DDoS-атакам и проводить тренировки по реагированию на инциденты.
Отказ в обслуживании (VA_5)		
Обеспечение устойчивости системы к DoS-атакам	Cloudflare 2021, Akamai Kona Site Defender 2021, Arbor Networks APS 5.0	Специалисту по реагированию на инциденты рекомендуется использовать Cloudflare и Akamai Kona Site Defender для защиты от DoS-атак и оптимизации распределения трафика. Arbor Networks APS следует использовать для анализа и предотвращения сложных DoS-атак. Настроить системы для автоматического мониторинга и анализа логов для быстрой реакции на инциденты.